

Seguridad de Sistemas Operativos

Hay muchas maneras de comprometer la seguridad de un sistema informático. A menudo no son nada sofisticadas. Por ejemplo, mucha gente pone su código PIN a 0000, o su contraseña a password, fácil de recordar, pero no muy segura. También hay gente que hace lo contrario. Eligen contraseñas muy complicadas, para no recordarlas, y tienen que escribirlas en una nota que pegan a su pantalla o teclado. De este modo, cualquier persona con acceso físico a la máquina también tiene acceso a todo lo que hay en la máquina. Hay muchos otros ejemplos, como el de los funcionarios que pierden memorias USB con información sensible, discos duros viejos con secretos comerciales que no se limpian adecuadamente antes de tirarlos a la papelera de reciclaje, etc.

Sin embargo, algunos de los incidentes de seguridad más importantes se deben a sofisticados ciberataques. En este texto, nos interesan específicamente los ataques relacionados con el sistema operativo. En otras palabras, no nos ocuparemos de los ataques a la web ni de los ataques a las bases de datos. En su lugar, nos centramos en los ataques en los que el sistema operativo es el objetivo del ataque o juega un papel importante en la aplicación (o, más comúnmente, en la no aplicación) de las políticas de seguridad.

Comenzaremos nuestro estudio de la seguridad aclarando alguna terminología. Algunas personas usan los términos *seguridad* y *protección* indistintamente. Sin embargo, a menudo es útil hacer una distinción entre los problemas generales que implica asegurarse de que los archivos no sean leídos o modificados por personas no autorizadas, que incluyen cuestiones técnicas, administrativas, legales y políticas, por un lado, y los mecanismos específicos del sistema operativo utilizados para proporcionar seguridad, por el otro.

Tanto la protección como la seguridad son vitales para los sistemas informáticos. Distinguiremos entre estos dos conceptos de la siguiente manera: la seguridad es una medida de confianza en que se preservará la integridad de un sistema y sus datos, mientras que la protección es el conjunto de mecanismos específicos del sistema operativo utilizados para salvaguardar la información en el equipo.

Más formalmente, podemos definir a la seguridad informática como la protección otorgada a un sistema de información automatizado para alcanzar los objetivos aplicables de preservar la integridad, disponibilidad y confidencialidad de los recursos del sistema de información en el que incluimos hardware, software, firmware, información / datos y telecomunicaciones.

Hoy en día, es difícil abrir un periódico sin leer otra historia sobre atacantes que entran en los sistemas informáticos, roban información o controlan millones de ordenadores. Si un sistema informático tiene varios usuarios y permite la ejecución simultánea de varios procesos, es necesario regular el acceso a los

datos. Para ello, existen mecanismos que garantizan que los archivos, los segmentos de memoria, la CPU y otros recursos puedan ser operados sólo por aquellos procesos que hayan obtenido la debida autorización del sistema operativo. Por ejemplo, el hardware de direccionamiento de memoria garantiza que un proceso sólo pueda ejecutarse dentro de su propio espacio de direcciones. El temporizador garantiza que ningún proceso pueda obtener el control de la CPU sin cederlo eventualmente. Los registros de control de dispositivos no son accesibles para los usuarios, por lo que la integridad de los distintos dispositivos periféricos está protegida.

La protección, por tanto, es cualquier mecanismo para controlar el acceso de los procesos o usuarios a los recursos definidos por un sistema informático. Este mecanismo debe proporcionar medios para especificar los controles que deben imponerse y para hacerlos cumplir. La protección puede mejorar la fiabilidad detectando los errores latentes en las interfaces entre los subsistemas componentes. La detección temprana de los errores de interfaz puede evitar a menudo la contaminación de un subsistema sano por otro que funciona mal. Además, un recurso no protegido no puede defenderse del uso (o mal uso) de un usuario no autorizado o incompetente. Un sistema orientado a la protección proporciona un medio para distinguir entre el uso autorizado y el no autorizado.

Un sistema puede tener una protección adecuada, pero seguir siendo propenso a los fallos y permitir un acceso inadecuado. Ante esto, una persona ingenua podría plantearse lógicamente dos preguntas sobre este estado de cosas:

1. ¿Es posible construir un sistema informático seguro?
2. Si es así, ¿por qué no se hace?

La respuesta a la primera es: En teoría, sí. En principio, el software puede estar libre de errores e incluso podemos verificar que es seguro, siempre que ese software no sea demasiado grande o complicado. Por desgracia, los sistemas informáticos de hoy en día son terriblemente complicados y esto tiene mucho que ver con la segunda pregunta. La segunda pregunta, por qué no se construyen sistemas seguros, se reduce a dos razones fundamentales.

En primer lugar, los sistemas actuales no son seguros, pero los usuarios no están dispuestos a deshacerse de ellos. Si Microsoft anunciara que, además de Windows, tiene un nuevo producto, SecureOS, resistente a los virus pero que no ejecuta aplicaciones de Windows, no es ni mucho menos seguro que todas las personas y empresas abandonen Windows tan rápido como puedan y compren el nuevo sistema inmediatamente. Podemos suponer que Microsoft tiene un sistema operativo seguro, pero no lo comercializa.

El segundo problema es más sutil. La única manera conocida de construir un sistema seguro es mantenerlo simple. Las características son el enemigo de la seguridad. La buena gente del departamento de marketing de la mayoría de las empresas tecnológicas cree (con razón o sin ella) que lo que los usuarios quieren

son más funciones, más grandes y mejores. Se aseguran de que los arquitectos de sistemas que diseñan sus productos lo entiendan. Sin embargo, todo esto significa más complejidad, más código, más bugs y más errores de seguridad.

Pensemos en un usuario al que le roban la información de autenticación (su forma de identificarse en el sistema). Sus datos podrían ser copiados o borrados, aunque la protección de archivos y de la memoria funcione. El trabajo de la seguridad es defender un sistema de ataques externos e internos.

Dichos ataques se extienden en un amplio abanico e incluyen virus y gusanos, ataques de denegación de servicio (que utilizan todos los recursos de un sistema y así mantienen a los usuarios legítimos fuera del sistema), robo de identidad y robo de servicio (uso no autorizado de un sistema). La prevención de algunos de estos ataques se considera una función del sistema operativo en algunos sistemas, mientras que otros lo dejan en manos de políticas o software adicional. Debido al alarmante aumento de los incidentes de seguridad, las funciones de seguridad de los sistemas operativos son un área de investigación e implementación en rápido crecimiento.

La protección y la seguridad requieren que el sistema sea capaz de distinguir entre todos sus usuarios. La mayoría de los sistemas operativos mantienen una lista de nombres de usuario y un identificador de usuario asociado (ID de usuario). En el lenguaje de Windows, se trata de un identificador de seguridad (SID). Estos identificadores numéricos son únicos, uno por usuario. Cuando un usuario se conecta al sistema, la etapa de autenticación determina el ID de usuario apropiado para el usuario. Ese ID de usuario se asocia a todos los procesos e hilos del usuario. Cuando un ID debe ser legible por un usuario, se traduce de nuevo al nombre de usuario a través de la lista de nombres de usuario.

En algunas circunstancias, deseamos distinguir entre conjuntos de usuarios en lugar de usuarios individuales. Por ejemplo, el propietario de un archivo en un sistema UNIX puede estar autorizado a realizar todas las operaciones en ese archivo, mientras que un conjunto seleccionado de usuarios puede estar autorizado sólo a leer el archivo. Para lograr esto, necesitamos definir un nombre de grupo y el conjunto de usuarios que pertenecen a ese grupo. La funcionalidad de los grupos puede implementarse como una lista de nombres de grupo y un identificador de grupo en todo el sistema. Un usuario puede estar en uno o más grupos, dependiendo de las decisiones de diseño del sistema operativo. Los identificadores de grupo del usuario también se incluyen en cada proceso e hilo asociado.

En el curso del uso normal del sistema, el ID de usuario y el ID de grupo de un usuario son suficientes. Sin embargo, a veces un usuario necesita escalar privilegios para obtener permisos adicionales para una actividad. El usuario puede necesitar acceso a un dispositivo que está restringido, por ejemplo. Los

sistemas operativos proporcionan varios métodos para permitir la escalada de privilegios. En UNIX, por ejemplo, el atributo *setuid* en un programa hace que éste se ejecute con el ID de usuario del propietario del archivo, en lugar del ID del usuario actual. El proceso se ejecuta con este UID efectivo hasta que desactiva los privilegios extra o se termina.

En otras palabras, la seguridad implica proteger los recursos informáticos contra el acceso no autorizado, la destrucción o alteración malintencionada y la introducción accidental de inconsistencias. Los recursos informáticos incluyen la información almacenada en el sistema, tanto datos como código, así como la CPU, la memoria interna, el almacenamiento externo y las redes que componen la instalación informática. Nos centraremos en la seguridad en este módulo y abordaremos la protección en el siguiente. En este módulo, comenzaremos examinando las formas en que los recursos pueden ser mal utilizados, ya sea accidental o malintencional, veremos las amenazas a la seguridad y los atacantes para ver cuál es la naturaleza del problema. Además, veremos los mecanismos y modelos de protección disponibles para ayudar a lograr la seguridad para protegerse o detectar ataques.

En realidad, hay algunas organizaciones que piensan que una buena seguridad es más importante que las nuevas características ingeniosas, siendo el ejército el principal ejemplo. En las siguientes secciones veremos algunas de las cuestiones implicadas, pero pueden resumirse en una frase. Para construir un sistema seguro, hay que tener un modelo de seguridad en el núcleo del sistema operativo que sea lo suficientemente sencillo como para que los diseñadores puedan entenderlo realmente, y resistir toda presión para desviarse de él con el fin de añadir nuevas características.

Resulta conveniente aclarar que, otros importantes elementos para la seguridad, algunos de los cuales ya los hemos mencionado, como son la criptografía, la Biblioteca de Infraestructura de Tecnologías de Información (ITIL), los niveles de aplicación, físico y humano, aunque son importantes, está en su mayor parte fuera del alcance de este curso y serán analizadas en otras asignaturas.

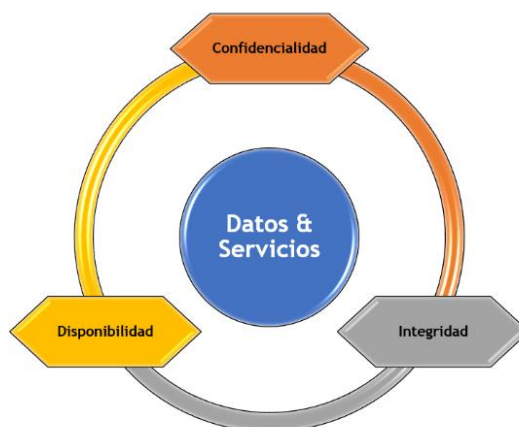
El problema de la seguridad

La definición de seguridad informática introduce tres objetivos clave que están en su núcleo:

1. Confidencialidad: Este término abarca dos conceptos relacionados:
 - a. Confidencialidad de los datos: Asegura que la información privada o confidencial no esté disponible o divulgada a personas no autorizadas

- b. Privacidad: Asegura que las personas controlan o influyen en qué información relacionada con ellas se puede recopilar y almacenar y por quién y a quién se puede divulgar esa información.
2. Integridad: Este término cubre dos conceptos relacionados:
- a. Integridad de los datos: Asegura que la información y los programas se cambien solo de una manera específica y autorizada.
 - b. Integridad del sistema: Asegura que un sistema realiza su función prevista de una manera no deteriorada, libre de manipulación no autorizada deliberada o inadvertida del sistema.
3. Disponibilidad: Asegura que los sistemas funcionen con prontitud y que el servicio no se niegue a los usuarios autorizados.

Estos tres conceptos forman lo que a menudo se denomina la tríada CIA (Confidentiality - Integrity - Availability). Los tres conceptos encarnan los objetivos fundamentales de seguridad tanto para los datos como para los servicios de información e informática.



Por ejemplo, la norma FIPS 199 del NIST (Standards for Security Categorization of Federal Information and Information Systems) enumera la confidencialidad, la integridad y la disponibilidad como los tres objetivos de seguridad para la información y para los sistemas de información. FIPS PUB 199 proporciona una caracterización útil de estos tres objetivos en términos de requisitos y la definición de una pérdida de seguridad en cada categoría:

- Confidencialidad: Preservación de las restricciones autorizadas para el acceso y la divulgación de la información, incluidos los medios para proteger la privacidad personal y la información de propiedad. Una pérdida de confidencialidad es la divulgación no autorizada de información.
- Integridad: Protección contra la modificación o destrucción indebida de la información, incluida la garantía de no rechazo y autenticidad de la información. Una pérdida de integridad es la modificación o destrucción no autorizada de la información.

- **Disponibilidad:** Garantizar el acceso oportuno y fiable a la información y su uso. Una pérdida de disponibilidad es la interrupción del acceso o del uso de la información o de un sistema de información.

Aunque el uso de la tríada de la CIA para definir los objetivos de seguridad está bien establecido, algunos en el campo de la seguridad consideran que se necesitan conceptos adicionales para presentar una imagen completa. Dos de los más mencionados son los siguientes:

- **Autenticidad:** La propiedad de ser genuino y poder ser verificado y confiado; la confianza en la validez de una transmisión, un mensaje o un emisor de mensajes. Esto significa verificar que los usuarios son quienes dicen ser y que cada entrada que llega al sistema proviene de una fuente de confianza. Observemos que FIPS PUB 199 incluye la autenticidad en la integridad.
- **Rendición de cuentas:** El objetivo de seguridad genera el requisito de que las acciones de una entidad puedan ser rastreadas de forma única hasta esa entidad. Esto apoya el no rechazo, la disuasión, el aislamiento de fallos, la detección y prevención de intrusiones, y la recuperación posterior y la acción legal. Dado que los sistemas verdaderamente seguros aún no son un objetivo alcanzable, debemos ser capaces de rastrear una violación de la seguridad hasta una parte responsable. Los sistemas deben mantener registros de sus actividades para permitir un análisis forense posterior que permita rastrear las violaciones de la seguridad o ayudar en las disputas sobre transacciones.

En muchas aplicaciones, garantizar la seguridad del sistema informático merece un esfuerzo considerable. Los grandes sistemas comerciales que contienen nóminas u otros datos financieros son objetivos que invitan a los ladrones. Los sistemas que contienen datos relativos a las operaciones corporativas pueden ser de interés para competidores sin escrúpulos.

Además, la pérdida de estos datos ya sea por accidente o por fraude, puede perjudicar seriamente la capacidad de funcionamiento de la empresa. Incluso los recursos informáticos en bruto son atractivos para los atacantes para la minería de bitcoin, para el envío de spam y como fuente desde la que atacar anónimamente otros sistemas.

En el siguiente módulo, veremos los mecanismos que el sistema operativo puede proporcionar (con la ayuda apropiada del hardware) que permiten a los usuarios proteger sus recursos, incluyendo programas y datos. Estos mecanismos funcionan bien sólo mientras los usuarios se ajusten al uso y acceso previsto de estos recursos.

Decimos que un sistema es seguro si sus recursos se utilizan y se accede a ellos según lo previsto en todas las circunstancias. Desgraciadamente, no se puede conseguir una seguridad total. No obstante, debemos disponer de mecanismos para que las violaciones de la seguridad sean un hecho raro y no la norma.

Las violaciones de la seguridad (o el mal uso) del sistema pueden clasificarse como malintencionadas o accidentales. Es más fácil protegerse contra un mal uso accidental que contra un mal uso malintencionado. En la mayoría de los casos, los mecanismos de protección son el núcleo para evitar los accidentes. La siguiente lista incluye varias formas de violaciones de seguridad accidentales y malintencionales. Tengamos en cuenta que, en nuestra discusión sobre la seguridad, utilizaremos los términos intruso, hacker y atacante para aquellos que intentan violar la seguridad. Además, una amenaza es el potencial de una violación de la seguridad, como el descubrimiento de una vulnerabilidad, mientras que un ataque es un intento de romper la seguridad.

- Violación de la confidencialidad. Este tipo de violación implica la lectura no autorizada de datos o el robo de información. Normalmente, la violación de la confidencialidad es el objetivo de un intruso. La captura de datos secretos de un sistema o de un flujo de datos, como información de tarjetas de crédito o de identidad para el robo de identidades, o películas o guiones inéditos, puede resultar directamente en dinero para el intruso y en vergüenza para la institución hackeada.
- Violación de la integridad. Esta violación implica la modificación no autorizada de los datos. Este tipo de ataque puede, por ejemplo, provocar el traspaso de la responsabilidad a una parte inocente o la modificación del código fuente de una importante aplicación comercial o de código abierto.
- Violación de la disponibilidad. Esta violación implica la destrucción no autorizada de datos. Algunos atacantes prefieren causar estragos y obtener estatus o derechos de fanfarronería que ganar económicamente. La desfiguración de sitios web es un ejemplo común de este tipo de violación de la seguridad.
- Robo de servicio. Esta violación implica el uso no autorizado de recursos. Por ejemplo, un intruso (o un programa de intrusión) puede instalar un demonio, o Daemonⁱ, en un sistema que actúa como servidor de archivos.
- Denegación de servicio (DOS). Esta violación implica impedir el uso legítimo del sistema. Los ataques de denegación de servicio (DOS) son a veces accidentales. El gusano original de Internet se convirtió en un ataque de DOS cuando un error no pudo retrasar su rápida propagación.

Los atacantes utilizan varios métodos estándar en sus intentos de violar la seguridad. El más común es el enmascaramiento, en el que un participante en una comunicación se hace pasar por otro, sea otro anfitrión u otra persona. Al hacerse pasar por otra persona, los atacantes violan la autenticación, es decir, la exactitud de la identificación; así pueden obtener un acceso que normalmente no se les permitiría. Otro ataque común es la repetición de un intercambio de datos capturado. Un ataque de repetición consiste en la repetición maliciosa o fraudulenta de una transmisión de datos válida.

A veces la respuesta comprende todo el ataque, por ejemplo, en la respuesta de una solicitud de transferencia de dinero. Pero con frecuencia se realiza junto con la modificación del mensaje, en la que el atacante cambia los datos de una comunicación sin que el remitente lo sepa. Pensemos en el daño que se podría hacer si una solicitud de autenticación tuviera la información de un usuario legítimo sustituida por la de un usuario no autorizado.

Otro tipo de ataque es el del intermediario, en el que un atacante se sitúa en el flujo de datos de una comunicación, haciéndose pasar por el emisor ante el receptor, y viceversa. En una comunicación de red, un ataque del intermediario puede ir precedido de un secuestro de sesión, en el que se intercepta una sesión de comunicación activa.

Otra amplia clase de ataques está dirigida a la escalada de privilegios. Todo sistema asigna privilegios a los usuarios, incluso si sólo hay un usuario y éste es el administrador. Generalmente, el sistema incluye varios conjuntos de privilegios, uno para cada cuenta de usuario y otros para el sistema. Con frecuencia, también se asignan privilegios a los no usuarios del sistema (como los usuarios de toda la Internet que acceden a una página web sin iniciar sesión o los usuarios anónimos de servicios como la transferencia de archivos). Incluso un remitente de correo electrónico a un sistema remoto puede considerarse que tiene privilegios: el privilegio de enviar un correo electrónico a un usuario receptor en ese sistema. La escalada de privilegios da a los atacantes más privilegios de los que se supone que tienen. Por ejemplo, un correo electrónico que contiene un script o una macro que se ejecuta excede los privilegios del remitente del correo electrónico. La suplantación de identidad y la modificación de mensajes, mencionadas anteriormente, se realizan a menudo para escalar privilegios. Hay muchos más ejemplos, ya que se trata de un tipo de ataque muy común. De hecho, es difícil detectar y prevenir todos los distintos ataques de esta categoría.

Como ya hemos sugerido, no es posible una protección absoluta del sistema contra los abusos malintencionados, pero el coste para el autor puede ser lo suficientemente alto como para disuadir a la mayoría de los intrusos. En algunos casos, como el de un ataque de denegación de servicio (DOS), es preferible evitar el ataque, pero basta con detectarlo para poder tomar contramedidas (como el filtrado ascendente o la adición de recursos para que el ataque no deniegue servicios a los usuarios legítimos).

Para proteger un sistema, debemos tomar medidas de seguridad en cuatro niveles:

- Físico. El sitio o los sitios que contienen los sistemas informáticos deben estar físicamente asegurados contra la entrada de intrusos. Tanto las salas de computadores como los terminales o computadores que tienen acceso a las máquinas objetivo deben estar asegurados, por ejemplo, limitando el acceso

al edificio en el que residen o bloqueando el escritorio en el que se encuentran.

- **Red.** La mayoría de los sistemas informáticos contemporáneos, desde los servidores hasta los dispositivos móviles, pasando por los dispositivos del Internet de las cosas (Internet of Things), están conectados en red. Las redes proporcionan un medio para que el sistema acceda a recursos externos, pero también proporcionan un vector potencial para el acceso no autorizado al propio sistema.

Además, los datos informáticos de los sistemas modernos viajan con frecuencia a través de líneas privadas alquiladas, líneas compartidas como Internet, conexiones inalámbricas y líneas de acceso telefónico. Interceptar estos datos puede ser tan perjudicial como irrumpir en un computador, y la interrupción de las comunicaciones puede constituir un ataque remoto de denegación de servicio, disminuyendo el uso y la confianza de los usuarios en el sistema.

- **Sistema operativo.** El sistema operativo y su conjunto integrado de aplicaciones y servicios constituyen una enorme base de código que puede albergar muchas vulnerabilidades. Las configuraciones inseguras por defecto, los errores de configuración y los fallos de seguridad son sólo algunos de los problemas potenciales. Por ello, los sistemas operativos deben mantenerse actualizados mediante la aplicación continua de parches y endurecidos, es decir, configurados y modificados para reducir la superficie de ataque y evitar la penetración. La superficie de ataque es el conjunto de puntos en los que un atacante puede intentar entrar en el sistema.
- **Aplicaciones.** Las aplicaciones de terceros también pueden plantear riesgos, especialmente si poseen privilegios importantes. Algunas aplicaciones son intrínsecamente dañinas, pero incluso las aplicaciones benignas pueden contener errores de seguridad. Debido al gran número de aplicaciones de terceros y a la disparidad de sus bases de código, es prácticamente imposible garantizar que todas esas aplicaciones sean seguras.

Este modelo de seguridad de cuatro capas lo podemos apreciar en la figura siguiente.

Tipo de ataque		Métodos de prevención de ataques
Errores lógicos. Defectos de diseño. Inyecciones de código.	⇒ Aplicación ⇐	Sandboxing. Restricciones de software.
Valores predeterminados inseguros. Vulnerabilidades de la plataforma.	⇒ Sistema operativo ⇐	Parches. Reconfiguración. Endurecimiento.
Fisgonear. Falsificar. Enmascarar.	⇒ Red ⇐	Cifrado. Autenticación. Filtrado.
Acceso a la terminal. Ataques basados en el hardware	⇒ Físico ⇐	Guardias. Bóvedas. Cifrado de datos de dispositivos.

El modelo de seguridad de cuatro capas es como una cadena hecha de eslabones: una vulnerabilidad en cualquiera de sus capas puede llevar a un compromiso total del sistema. En este sentido, es cierto el viejo refrán de que la seguridad es tan fuerte como su eslabón más débil.

Otro factor que no se puede pasar por alto es el humano. La autorización debe realizarse cuidadosamente para garantizar que sólo los usuarios autorizados y de confianza tengan acceso al sistema. Sin embargo, incluso los usuarios autorizados pueden ser malintencionados o pueden ser alentados a permitir que otros utilicen su acceso, ya sea por voluntad propia o cuando son engañados a través de las relaciones humanas, que utiliza el engaño para persuadir a la gente a dar información confidencial. Un tipo de ataque como el mencionado es el phishing, en el que un correo electrónico o una página web de aspecto legítimo engañan al usuario para que introduzca información confidencial. A veces, basta con hacer clic en un enlace en una página del navegador o en un correo electrónico para descargar inadvertidamente una carga útil dañina, comprometiendo la seguridad del sistema en el computador del usuario. Por lo general, ese PC no es el objetivo final, sino algún recurso más valioso. A partir de ese sistema comprometido, se producen ataques a otros sistemas de la LAN o a otros usuarios.

Hasta ahora, hemos visto que los cuatro factores del modelo de cuatro niveles, más el factor humano, deben tenerse en cuenta si se quiere mantener la seguridad. Además, el sistema debe proporcionar protección para permitir la implantación de elementos de seguridad. Sin la capacidad de autorizar a los usuarios y procesos para controlar su acceso, y de registrar sus actividades, sería imposible que un sistema operativo aplicara medidas de seguridad o se ejecutara de forma segura. Las características de protección del hardware son necesarias para apoyar un esquema de protección general. Por ejemplo, un sistema sin protección de la memoria no puede ser seguro. Las nuevas características del hardware están permitiendo que los sistemas sean más seguros, como veremos.

Por desgracia, pocas cosas en materia de seguridad son sencillas. A medida que los intrusos explotan las vulnerabilidades de seguridad, se crean y despliegan contramedidas de seguridad. Esto hace que los intrusos se vuelvan más sofisticados en sus ataques. Por ejemplo, el software espía puede proporcionar un conducto para el spam a través de sistemas inocentes, que a su vez puede entregar ataques de phishing a otros objetivos. Es probable que este juego del gato y el ratón continúe, y que se necesiten más herramientas de seguridad para bloquear las crecientes técnicas y actividades de los intrusos.

En el resto de este módulo, abordamos la seguridad a nivel de sistema operativo. La seguridad dentro del sistema operativo y entre sistemas operativos se implementa de varias maneras, que van desde las contraseñas

para la autenticación hasta la protección contra los virus y la detección de intrusiones. Comenzamos con una exploración de las amenazas a la seguridad.

Amenazas al programa y al sistema

Ya hemos mencionado que, en muchos textos sobre seguridad, se descompone a la seguridad de un sistema de información en tres componentes: confidencialidad, integridad y disponibilidad. Juntos constituyen las propiedades de seguridad fundamentales que debemos proteger contra atacantes e intrusos. Más tarde, las personas decidieron que tres propiedades fundamentales no eran suficientes para todos los escenarios posibles, por lo que agregaron otras adicionales, como la autenticidad, la responsabilidad, la privacidad y otras. Claramente, todas ellas son agradables de tener. Aun así, las tres originales todavía ocupan un lugar especial en la consideración mental de la mayoría de los expertos en seguridad.

Los procesos, junto con el kernel, son el único medio para realizar el trabajo en un computador. Por lo tanto, escribir un programa que cree una brecha de seguridad, o hacer que un proceso normal cambie su comportamiento y cree una brecha, es un objetivo común de los atacantes. De hecho, incluso la mayoría de los eventos de seguridad no relacionados con programas tienen como objetivo causar una amenaza a un programa. Por ejemplo, aunque es útil entrar en un sistema sin autorización, es mucho más útil dejar un demonio de puerta trasera o una herramienta de acceso remoto (RAT: **Remote Access Tool**) que proporcione información o permita un acceso fácil incluso si el programa original está bloqueado. En esta sección, describimos los métodos más comunes por los que los programas causan violaciones de seguridad. Tengamos en cuenta que hay una variación considerable en las convenciones de denominación de las fallas de seguridad y que utilizaremos los términos más comunes o descriptivos. Pasemos entonces ahora a analizar las amenazas, los ataques y los recursos relacionados con la seguridad informática.

Amenazas y ataques

En la actualidad es posible describir cuatro tipos de consecuencias de las amenazas y enumerar los tipos de ataques que dan lugar a cada consecuencia.

- La divulgación no autorizada es una amenaza a la confidencialidad. Los siguientes tipos de ataques pueden resultar una consecuencia de esta amenaza:
 - **Exposición:** Puede ser deliberada, como cuando una persona con información privilegiada divulga intencionadamente información sensible, como números de tarjetas de crédito, a una persona ajena. También puede ser el resultado de un error humano, de hardware o de software, que hace que una entidad tenga conocimiento no autorizado

de datos sensibles. Ha habido numerosos casos de este tipo, como el de las universidades que publican accidentalmente información confidencial de los estudiantes en la web.

- **Intercepción:** La intercepción es un ataque común en el contexto de las comunicaciones. En una red de área local (LAN) compartida, como una LAN inalámbrica o una Ethernet de difusión, cualquier dispositivo conectado a la LAN puede recibir una copia de los paquetes destinados a otro dispositivo. En Internet, un hacker decidido puede acceder al tráfico de correo electrónico y a otras transferencias de datos. Todas estas situaciones crean la posibilidad de un acceso no autorizado a los datos.
- **Inferencia:** Un ejemplo de inferencia es el conocido como análisis de tráfico, en el que un adversario es capaz de obtener información a partir de la observación del patrón de tráfico en una red, como la cantidad de tráfico entre determinados pares de hosts en la red. Otro ejemplo es la inferencia de información detallada de una base de datos por parte de un usuario que sólo tiene acceso limitado; esto se logra mediante consultas repetidas cuyos resultados combinados permiten la inferencia.
- **Intrusión:** Un ejemplo de intrusión es que un adversario obtenga acceso no autorizado a datos sensibles superando las protecciones de control de acceso del sistema.
- El engaño es una amenaza para la integridad del sistema o de los datos. Los siguientes tipos de ataques pueden ser una consecuencia de esta amenaza:
 - **Enmascaramiento:** Un ejemplo de enmascaramiento es el intento de un usuario no autorizado de obtener acceso a un sistema haciéndose pasar por un usuario autorizado; esto podría ocurrir si el usuario no autorizado ha aprendido el ID de inicio de sesión y la contraseña de otro usuario. Otro ejemplo es el software malintencionado, como un caballo de Troya, que parece realizar una función útil o deseable, pero que en realidad obtiene acceso no autorizado a los recursos del sistema o engaña al usuario para que ejecute otro software malintencionado.
 - **Falsificación:** Se refiere a la alteración o sustitución de datos válidos o a la introducción de datos falsos en un archivo o base de datos. Por ejemplo, un estudiante puede alterar sus calificaciones en una base de datos escolar.
 - **Negación:** En este caso, un usuario niega el envío de datos o un usuario niega la recepción o posesión de los datos.
- La interrupción es una amenaza para la disponibilidad o la integridad del sistema. Los siguientes tipos de ataques pueden ser una consecuencia de esta amenaza:

- Incapacitación: Se trata de un ataque a la disponibilidad del sistema. Puede producirse como resultado de la destrucción física o el daño del hardware del sistema. Más típicamente, el software malintencionado, como los caballos de Troya, los virus o los gusanos, podría operar de tal manera que inhabilite un sistema o algunos de sus servicios.
- Corrupción: Se trata de un ataque a la integridad del sistema. El software malintencionado en este contexto podría operar de tal manera que los recursos o servicios del sistema funcionen de manera no deseada. O un usuario podría obtener acceso no autorizado a un sistema y modificar algunas de sus funciones. Un ejemplo de esto último es que un usuario coloque una lógica de puerta trasera en el sistema para proporcionar un acceso posterior a un sistema y sus recursos por un procedimiento distinto al habitual.
- Obstrucción: Una forma de obstruir el funcionamiento del sistema es interferir en las comunicaciones inutilizando los enlaces de comunicación o alterando la información de control de las comunicaciones. Otra forma es sobrecargar el sistema imponiendo una carga excesiva al tráfico de comunicaciones o a los recursos de procesamiento.
- La usurpación es una amenaza para la integridad del sistema. Los siguientes tipos de ataques pueden ser una consecuencia esta amenaza:
 - Apropiación indebida: Esto puede incluir el robo de servicio. Un ejemplo es un ataque de denegación de servicio distribuido, cuando se instala software malintencionado en una serie de hosts para utilizarlo como plataforma para lanzar tráfico a un host objetivo. En este caso, el software malicioso hace un uso no autorizado de los recursos del procesador y del sistema operativo.
 - Uso indebido: El uso indebido puede producirse por medio de un software malintencionado o por un pirata informático que haya obtenido acceso no autorizado a un sistema. En cualquiera de los dos casos, las funciones de seguridad pueden desactivarse o frustrarse.

Amenazas y recursos

Los recursos de un sistema informático pueden clasificarse en software, hardware, datos y líneas y redes de comunicación. En esta subsección describimos brevemente estas cuatro categorías y las relacionamos con los conceptos de integridad, confidencialidad y disponibilidad.

- **Software.** El software incluye el sistema operativo, las utilidades y los programas de aplicación. Una amenaza clave para el software es un ataque a la disponibilidad. El software, especialmente el de aplicación, suele ser fácil de borrar. El software también puede ser alterado o dañado para hacerlo inútil. La gestión cuidadosa de la configuración del software, que

incluye la realización de copias de seguridad de la versión más reciente del software, puede mantener una alta disponibilidad. Un problema más difícil de tratar es la modificación del software que da lugar a un programa que sigue funcionando pero que se comporta de forma diferente a la anterior, lo que supone una amenaza para la integridad/autenticidad. Los virus informáticos y los ataques relacionados entran en esta categoría. Un último problema es la protección contra la piratería de software. Aunque existen algunas contramedidas, en general no se ha resuelto el problema de la copia no autorizada de software.

- **Hardware.** Una de las principales amenazas para el hardware de los sistemas informáticos es la amenaza a la disponibilidad. El hardware es el más vulnerable a los ataques y el menos susceptible a los controles automatizados. Las amenazas incluyen daños accidentales y deliberados a los equipos, así como el robo. La proliferación de equipos personales de toda clase y de estaciones de trabajo y el uso generalizado de las redes LAN aumentan el potencial de pérdidas en este ámbito. El robo de distintos medios de almacenamiento masivo (CD-ROM's, DVD's, BrD's, HDD's, SSD's, Flash drives, etc.) puede conducir a la pérdida de confidencialidad. Se necesitan medidas de seguridad física y administrativa para hacer frente a estas amenazas.
- **Datos.** La seguridad del hardware y del software suelen ser preocupaciones de los profesionales de los centros informáticos o preocupaciones individuales de los usuarios de ordenadores personales. Un problema mucho más extendido es la seguridad de los datos, que afecta a los archivos y otras formas de datos controlados por individuos, grupos y organizaciones empresariales.

Las preocupaciones de seguridad con respecto a los datos son amplias y abarcan la disponibilidad, el secreto y la integridad. En el caso de la disponibilidad, la preocupación se centra en la destrucción de los archivos de datos, que puede producirse de forma accidental o malintencionada.

La preocupación obvia por el secreto es la lectura no autorizada de archivos de datos o bases de datos, y esta área ha sido objeto de tal vez más investigación y esfuerzo que cualquier otra área de la seguridad informática. Una amenaza menos obvia para el secreto tiene que ver con el análisis de datos y se manifiesta en el uso de las llamadas bases de datos estadísticas, que proporcionan información resumida o agregada. Presumiblemente, la existencia de información agregada no amenaza la privacidad de los individuos involucrados.

Sin embargo, a medida que aumenta el uso de las bases de datos estadísticas, aumenta el potencial de divulgación de información personal. En esencia, las características de los individuos que las componen pueden

identificarse mediante un análisis cuidadoso. Por ejemplo, si una tabla registra el agregado de los ingresos de los encuestados A, B, C y D y otra registra el agregado de los ingresos de A, B, C, D y E, la diferencia entre los dos agregados sería el ingreso de E. Este problema se agrava por el creciente deseo de combinar conjuntos de datos. En muchos casos, el cotejo de varios conjuntos de datos para su coherencia en diferentes niveles de agregación requiere el acceso a las unidades individuales. Por lo tanto, las unidades individuales, que son objeto de preocupación por la privacidad, están disponibles en varias etapas del procesamiento de los conjuntos de datos.

Por último, la integridad de los datos es una de las principales preocupaciones en la mayoría de las instalaciones. Las modificaciones de los archivos de datos pueden tener consecuencias que van desde leves hasta desastrosas.

- **Líneas y redes de comunicación.** En general, distinguimos entre los ataques que tratan de robar información de forma pasiva, *ataques pasivos*, y los que intentan activamente que un programa informático se comporte mal, *ataques activos*. Un ataque pasivo intenta aprender o hacer uso de la información del sistema, pero no afecta los recursos del sistema. Por lo contrario, un ataque activo intenta alterar los recursos del sistema o afectar su funcionamiento.

Los ataques pasivos consisten en la escucha o monitorización de las transmisiones. El objetivo del atacante es obtener la información que se está transmitiendo. Dos tipos de ataques pasivos son la divulgación del contenido de los mensajes y el análisis del tráfico. El concepto de divulgación del contenido de los mensajes es fácil de entender. Una conversación telefónica, un mensaje de correo electrónico y un archivo transferido pueden contener información sensible o confidencial. Queremos evitar que un adversario conozca el contenido de estas transmisiones.

Un ejemplo de ataque pasivo es un adversario que husmea el tráfico de la red e intenta romper el cifrado (si lo hay) para llegar a los datos. En un ataque activo, el intruso puede tomar el control del navegador web de un usuario para hacer que ejecute un código malicioso, por ejemplo, para robar los datos de una tarjeta de crédito. En la misma línea, distinguimos entre la criptografía, que consiste en modificar un mensaje o un archivo de tal manera que sea difícil recuperar los datos originales a menos que se tenga la clave, y el fortalecimiento del software, que añade mecanismos de protección a los programas para dificultar que los atacantes los hagan funcionar mal. El sistema operativo utiliza la criptografía en muchos lugares: para transmitir datos de forma segura a través de la red, para almacenar archivos de forma segura en el disco, para codificar las contraseñas en un archivo de contraseñas, etc. El fortalecimiento de los programas también se utiliza en todas partes: para evitar que los atacantes

inyecten nuevo código en el software en ejecución, para asegurarse de que cada proceso tiene exactamente los privilegios que necesita para hacer lo que se supone que debe hacer y nada más, etc.

El análisis del tráfico es una forma más sutil de ataque pasivo. Supongamos que tenemos una forma de enmascarar el contenido de los mensajes u otro tráfico de información para que los adversarios, aunque capturen el mensaje, no puedan extraer la información de este. La técnica habitual para enmascarar los contenidos es el cifrado. Si tuviéramos una protección de cifrado, un adversario podría seguir observando el patrón de estos mensajes. El adversario podría determinar la ubicación y la identidad de los hosts que se comunican y podría observar la frecuencia y la longitud de los mensajes que se intercambian. Esta información podría ser útil para adivinar la naturaleza de la comunicación que estaba teniendo lugar.

Los ataques pasivos son muy difíciles de detectar porque no implican ninguna alteración de los datos. Normalmente, el tráfico de mensajes se envía y se recibe de forma aparentemente normal, y ni el emisor ni el receptor son conscientes de que un tercero ha leído los mensajes u observado el patrón de tráfico. Sin embargo, es posible evitar el éxito de estos ataques, normalmente mediante el cifrado. Por lo tanto, el énfasis en el tratamiento de los ataques pasivos está en la prevención más que en la detección.

Los ataques activos implican alguna modificación del flujo de datos o la creación de un flujo falso y pueden subdividirse en cuatro categorías: reenvío, enmascaramiento, modificación de mensajes y denegación de servicio. Analicemos brevemente cada uno:

- El reenvío implica la captura pasiva de una unidad de datos y su posterior retransmisión para producir un efecto no autorizado.
- Un enmascaramiento tiene lugar cuando una entidad se hace pasar por otra diferente. Un ataque de enmascaramiento suele incluir una de las otras formas de ataque activo. Por ejemplo, las secuencias de autenticación pueden ser capturadas y reproducidas después de que una secuencia de autenticación válida haya tenido lugar, permitiendo así que una entidad autorizada con pocos privilegios obtenga privilegios adicionales haciéndose pasar por una entidad que tiene esos privilegios.
- La modificación de mensajes significa simplemente que alguna parte de un mensaje legítimo se altera, o que los mensajes se retrasan o reordenan, para producir un efecto no autorizado. Por ejemplo, un mensaje que dice "Permitir a Juan Cúper leer cuentas de archivos confidenciales" se modifica para decir "Permitir a Francisco Brown leer cuentas de archivos confidenciales".

- La denegación de servicio impide o inhibe el uso o la gestión normal de las instalaciones de comunicaciones. Este ataque puede tener un objetivo específico; por ejemplo, una entidad puede suprimir todos los mensajes dirigidos a un destino concreto (por ejemplo, el servicio de auditoría de seguridad). Otra forma de denegación de servicio es la interrupción de toda una red, ya sea deshabilitando la red o sobrecargándola con mensajes de manera que se degrade el rendimiento.

Los ataques activos presentan las características opuestas a los ataques pasivos. Mientras que los ataques pasivos son difíciles de detectar, existen medidas para evitar su éxito. En cambio, es bastante difícil impedir absolutamente los ataques activos, porque para ello habría que proteger físicamente todas las instalaciones y vías de comunicación en todo momento. En su lugar, el objetivo es detectarlos y recuperarse de cualquier interrupción o retraso causado por ellos. Como la detección tiene un efecto disuasorio, también puede contribuir a la prevención.

Intrusos

Un sistema operativo asocia un conjunto de privilegios a cada proceso. Estos privilegios dictan a qué recursos puede acceder el proceso, incluyendo regiones de memoria, archivos, instrucciones privilegiadas del sistema, etc. Normalmente, un proceso que se ejecuta en nombre de un usuario tiene los privilegios que el SO reconoce para ese usuario. Un proceso de sistema o de utilidad puede tener privilegios asignados en el momento de la configuración.

En un sistema típico, el nivel más alto de privilegios se denomina acceso de administrador, supervisor o raíz. El acceso de administrador proporciona acceso a todas las funciones y servicios del sistema operativo. Con el acceso de administrador, un proceso tiene el control total del sistema y puede añadir o cambiar programas y archivos, supervisar otros procesos, enviar y recibir tráfico de red y alterar los privilegios.

Una cuestión de seguridad clave en el diseño de cualquier sistema operativo es evitar, o al menos detectar, los intentos de un usuario o de una pieza de software malintencionado (malware) de obtener privilegios no autorizados en el sistema y, en particular, de obtener acceso de administrador. Resumiremos brevemente las amenazas y contramedidas relacionadas con este problema de seguridad. Podemos establecer que las amenazas de acceso al sistema se dividen en dos categorías generales: intrusos y software malintencionado. Veamos a la primera de estas categorías.

Una de las amenazas más comunes para la seguridad es el intruso (la otra son los virus), a menudo denominado hacker o cracker. En un importante estudio sobre la intrusión, Anderson¹ identificó tres clases de intrusos:

- **Hacker, infiltrado, cracker o enmascarado:** Individuo que no está autorizado a utilizar el computador y que penetra en los controles de acceso de un sistema para explotar la cuenta de un usuario legítimo.
- **Falsificador:** Un usuario legítimo que accede a datos, programas o recursos para los que no está autorizado dicho acceso, o que está autorizado para dicho acceso, pero hace mal uso de sus privilegios.
- **Usuario clandestino:** Un individuo que se apodera del control de supervisión del sistema y utiliza este control para evadir la auditoría y los controles de acceso o para suprimir la recopilación de auditorías.

El hacker es probablemente una persona ajena al sistema; el falsificador suele ser una persona interna; y el usuario clandestino puede ser una persona ajena al sistema o una persona interna.

Los ataques de intrusos van de lo benigno a lo grave. En el extremo benigno de la escala, hay muchas personas que simplemente desean explorar Internet y ver lo que hay. En el extremo serio están los individuos que intentan leer datos privilegiados, realizar modificaciones no autorizadas en los datos o interrumpir el sistema.

El objetivo del intruso es obtener acceso a un sistema o aumentar el rango de privilegios accesibles en un sistema. La mayoría de los ataques iniciales utilizan vulnerabilidades del sistema o del software que permiten a un usuario ejecutar código que abre una puerta trasera en el sistema. Los intrusos pueden obtener acceso a un sistema explotando ataques como desbordamientos de búfer en un programa que se ejecuta con ciertos privilegios.

Otra posibilidad es que el intruso intente adquirir información que debería estar protegida. En algunos casos, esta información tiene la forma de una contraseña de usuario. Con el conocimiento de la contraseña de algún otro usuario, un intruso puede entrar en un sistema y ejercer todos los privilegios concedidos al usuario legítimo.

En la siguiente lista tenemos algunos ejemplos de intrusión:

- Vulnerar un servidor web.
- Adivinar y descifrar contraseñas.
- Copiar una base de datos que contenga números de tarjetas de crédito.

¹ Anderson, J. Computer Security Threat Monitoring and Surveillance

- Ver datos confidenciales, incluyendo registros de nóminas e información médica, sin autorización.
- Ejecutar un rastreador de paquetes en una estación de trabajo para capturar nombres de usuario y contraseñas.
- Utilizar un error de permiso en un servidor FTP anónimo para distribuir software y archivos de música pirateados.
- Marcar en un módem no seguro y obtener acceso a la red interna.
- Hacerse pasar por un ejecutivo, llamar al servicio de asistencia, restablecer la contraseña del correo electrónico del ejecutivo y aprender la nueva contraseña.
- Utilizar una estación de trabajo desatendida y conectada sin permiso.

Las técnicas y patrones de comportamiento de los intrusos cambian constantemente, para explotar las debilidades recién descubiertas y evadir la detección y las contramedidas. Aun así, los intrusos suelen seguir una serie de patrones de comportamiento reconocibles, y estos patrones suelen diferir de los de los usuarios normales. A continuación, veremos los ejemplos de patrones de comportamiento de los intrusos para poder hacernos una idea del reto al que se enfrenta el administrador de seguridad.

Tradicionalmente, los que hackean ordenadores lo hacen por la emoción o por el estatus. La comunidad de hackers es una fuerte meritocracia en la que el estatus está determinado por el nivel de competencia. Así, los atacantes suelen buscar objetivos de oportunidad y luego comparten la información con otros. Un ejemplo típico es la irrupción en una gran institución financiera. El intruso se aprovechó del hecho de que la red corporativa estaba ejecutando servicios sin protección, algunos de los cuales ni siquiera eran necesarios. En este caso, la clave de la intrusión fue la aplicación pcAnywhere. El fabricante, Symantec, anuncia este programa como una solución de control remoto que permite la conexión segura a dispositivos remotos. Pero al atacante le resultó fácil acceder a pcAnywhere; el administrador utilizó el mismo nombre de usuario y contraseña de tres letras para el programa. En este caso, no había ningún sistema de detección de intrusos en la red corporativa de 700 nodos. El intruso sólo fue descubierto cuando una vicepresidenta entró en su despacho y vio el cursor moviendo archivos en su estación de trabajo Windows.

Los intrusos benignos pueden ser tolerables, aunque consumen recursos y pueden ralentizar el rendimiento de los usuarios legítimos. Sin embargo, no hay forma de saber de antemano si un intruso será benigno o maligno. Por lo tanto, incluso para los sistemas que no tienen recursos especialmente sensibles, existe una motivación para controlar este problema.

Los sistemas de detección de intrusos (IDS) y los sistemas de prevención de intrusos (IPS), del tipo descrito más adelante en el presente módulo, están

diseñados para contrarrestar este tipo de amenaza de los hackers. Además de utilizar estos sistemas, las organizaciones pueden considerar restringir los inicios de sesión remotos a direcciones IP específicas y/o utilizar tecnología de red privada virtual.

Uno de los resultados de la creciente concienciación sobre el problema de los intrusos ha sido la creación de una serie de equipos de respuesta a emergencias informáticas (CERT). Estas empresas cooperativas recogen información sobre las vulnerabilidades de los sistemas y la difunden entre los gestores de estos. Los hackers también leen habitualmente los informes de los CERT. Por ello, es importante que los administradores de sistemas introduzcan rápidamente todos los parches de software para las vulnerabilidades descubiertas. Desgraciadamente, dada la complejidad de muchos sistemas informáticos y el ritmo al que se publican los parches, esto es cada vez más difícil de conseguir sin una actualización automatizada. Incluso en ese caso, hay problemas causados por las incompatibilidades resultantes del software actualizado (de ahí la necesidad de múltiples capas de defensa en la gestión de las amenazas a la seguridad de los sistemas informáticos).

Asimismo, los grupos organizados de piratas informáticos se han convertido en una amenaza generalizada y común para los sistemas basados en Internet. Estos grupos pueden estar al servicio de una corporación o de un gobierno, pero a menudo son bandas de piratas informáticos con escasa afiliación. Un objetivo común es un archivo de tarjeta de crédito en un servidor de comercio electrónico. Los atacantes intentan obtener acceso de administrador. Los números de las tarjetas son utilizados por las bandas de delincuencia organizada para comprar artículos caros y luego se publican en los sitios de los emisores de tarjetas, donde otros pueden acceder y utilizar los números de cuenta; esto oscurece los patrones de uso y complica la investigación.

Mientras que los hackers tradicionales buscan objetivos de oportunidad, los hackers criminales suelen tener objetivos específicos, o al menos clases de objetivos en mente. Una vez que un sitio es penetrado, el atacante actúa rápidamente, recogiendo toda la información valiosa posible y saliendo. Los IDS y los IPS también pueden utilizarse para este tipo de atacantes, pero pueden ser menos eficaces debido a la naturaleza de entrada y salida rápida del ataque. En el caso de los sitios de comercio electrónico, debe utilizarse el cifrado de las bases de datos para la información sensible de los clientes, especialmente las tarjetas de crédito. En el caso de los sitios de comercio electrónico (proporcionados por un servicio externo), la organización de comercio electrónico debe hacer uso de un servidor dedicado (que no se utilice para dar soporte a múltiples clientes) y supervisar de cerca los servicios de seguridad del proveedor.

Los ataques internos son de los más difíciles de detectar y prevenir. Los empleados ya tienen acceso y conocimiento de la estructura y el contenido de

las bases de datos corporativas. Los ataques internos pueden estar motivados por la venganza o simplemente por un sentimiento de derecho. En cuanto a la sensación de derecho, siempre ha habido muchos empleados que se sentían con derecho a llevarse material de oficina extra para usar en casa, pero ahora esto se extiende a los datos corporativos.

Aunque las instalaciones de IDS e IPS pueden ser útiles para contrarrestar los ataques internos, otros enfoques más directos son de mayor prioridad. Algunos ejemplos son los siguientes:

- Imponer el privilegio mínimo, permitiendo sólo el acceso a los recursos que los empleados necesitan para hacer su trabajo.
- Establecer registros para ver a qué acceden los usuarios y qué comandos introducen.
- Proteger los recursos sensibles con una autenticación fuerte.
- En el momento del cese de actividades del empleado, eliminar el acceso del empleado al computador y a la red.
- Tras el despido del empleado, hacer una imagen espejo del disco duro del empleado por si es necesario demandarlo. Esas pruebas podrían ser necesarias si la información de la empresa aparece en un competidor.

El objetivo del intruso es obtener acceso a un sistema o aumentar el rango de privilegios accesibles en un sistema. La mayoría de los ataques iniciales utilizan vulnerabilidades del sistema o del software que permiten a un usuario ejecutar código que abre una puerta trasera en el sistema. Los intrusos pueden obtener acceso a un sistema explotando ataques como desbordamientos de búfer en un programa que se ejecuta con ciertos privilegios.

Otra posibilidad es que el intruso intente adquirir información que debería estar protegida. En algunos casos, esta información tiene la forma de una contraseña de usuario. Con el conocimiento de la contraseña de algún otro usuario, un intruso puede entrar en un sistema y ejercer todos los privilegios concedidos al usuario legítimo.

Pérdida accidental de datos

Además de las amenazas ocasionadas por los intrusos maliciosos, por accidente se pueden perder datos valiosos. Algunas de las causas comunes de pérdida accidental de datos son:

- Accidentes y desastres naturales: incendios, inundaciones, terremotos, guerras, disturbios, etc.
- Errores de hardware o software: fallas en la CPU, discos o cintas que no se pueden leer, errores de telecomunicaciones, errores en los programas.

- Errores humanos: error al introducir los datos, al conectar una unidad externa de almacenamiento masivo de manera incorrecta; ejecutar el programa incorrecto, perder un soporte de almacenamiento, o cualquier otro error.

La mayoría de estas causas se pueden prevenir mediante la realización de respaldos adecuados que se guardan, de preferencia, lejos de los datos originales. Aunque la acción de proteger los datos contra pérdidas accidentales puede parecer mundana en comparación con la acción de proteger contra intrusos astutos, en la práctica es probable que haya más daños ocasionados por las pérdidas accidentales que por intrusos.

Malware

Tal vez los tipos más sofisticados de amenazas a los sistemas informáticos sean los programas que explotan las vulnerabilidades de los sistemas informáticos. Estas amenazas se denominan *malware* y son un software diseñado para causar daños o utilizar los recursos de un computador objetivo. A menudo se ocultan dentro de un software legítimo o se hacen pasar por él. En algunos casos, se propaga a otros ordenadores a través del correo electrónico o de discos infectados. La terminología en esta área presenta problemas debido a la falta de acuerdo universal sobre todos los términos y porque algunas de las categorías se solapan. En este contexto, nos preocupan las amenazas a los programas de aplicación, así como a los programas de utilidad, como editores y compiladores, y a los programas a nivel del núcleo.

Los programas que forman parte del malware pueden dividirse en dos categorías: los que necesitan un programa anfitrión y los que son independientes. Los primeros, denominados parásitos, son esencialmente fragmentos de programas que no pueden existir independientemente de algún programa de aplicación, utilidad o programa de sistema real. Los virus, las bombas lógicas y las puertas traseras son ejemplos de ello. Los segundos son programas autónomos que pueden ser programados y ejecutados por el sistema operativo. Los gusanos y los programas bot son ejemplos.

También podemos diferenciar entre las amenazas de software que no se replican y las que sí lo hacen. Las primeras son programas o fragmentos de programas que se activan mediante un disparador. Algunos ejemplos son las bombas lógicas, las puertas traseras y los programas bot. Las segundas consisten en un fragmento de programa o en un programa independiente que, cuando se ejecuta, puede producir una o más copias de sí mismo para ser activadas posteriormente en el mismo sistema o en algún otro. Los virus y los gusanos son ejemplos de ello.

Los programas del malware pueden ser relativamente inofensivos o pueden realizar una o más de una serie de acciones dañinas, incluyendo la destrucción

de archivos y datos en la memoria principal, la evasión de los controles para obtener acceso privilegiado y la provisión de un medio para que los intrusos evadan los controles de acceso.

Con la siguiente lista, repasaremos brevemente algunas de las categorías clave del malware, aplazando la discusión sobre los temas clave de los virus, gusanos, bots y rootkits para otras asignaturas.

- **Virus:** Malware que, cuando se ejecuta, intenta replicarse en otro código ejecutable; cuando lo consigue, se dice que el código está infectado. Cuando el código infectado se ejecuta, el virus también se ejecuta.
- **Gusano:** Programa informático que puede ejecutarse de forma independiente y puede propagar una versión completa de sí mismo a otros hosts de una red.
- **Bomba lógica:** Programa insertado en el software por un intruso. Una bomba lógica permanece inactiva hasta que se cumple una condición predefinida; entonces el programa desencadena un acto no autorizado.
- **Caballo de Troya:** Programa informático que parece tener una función útil pero que también tiene una función oculta y potencialmente malintencionada que evade los mecanismos de seguridad, a veces explotando las autorizaciones legítimas de una entidad del sistema que invoca el programa troyano.
- **Puerta trasera (trapdoor):** Cualquier mecanismo que eluda un control de seguridad normal; puede permitir el acceso no autorizado a la funcionalidad.
- **Código móvil:** Software (por ejemplo, script, macro u otra instrucción portátil) que puede ser enviado sin cambios a una colección heterogénea de plataformas y ejecutarse con idéntica semántica.
- **Exploits:** Código específico para una sola vulnerabilidad o conjunto de vulnerabilidades.
- **Downloaders:** Programa que instala otros elementos en una máquina que está siendo atacada. Normalmente, un descargador se envía en un correo electrónico.
- **Auto-rooter:** Herramientas malware de los hackers utilizadas para entrar en nuevas máquinas de forma remota.
- **Kit (generador de virus):** Conjunto de herramientas para generar nuevos virus de forma automática.
- **Programas de spam:** Utilizados para enviar grandes volúmenes de correo electrónico no deseado.

- Flooders: Utilizados para atacar sistemas informáticos en red con un gran volumen de tráfico para llevar a cabo un ataque de denegación de servicio (DoS).
- Keyloggers: Captura las pulsaciones del teclado en un sistema comprometido.
- Rootkit: Conjunto de herramientas de hacker que se utilizan después de que el atacante haya entrado en un sistema informático y haya obtenido acceso a nivel de raíz.
- Zombi, bot: Programa activado en una máquina infectada que se activa para lanzar ataques a otras máquinas.
- Spyware: Software que recoge información de un ordenador y la transmite a otro sistema.
- Adware: Publicidad que se integra en el software. Puede dar lugar a anuncios emergentes o a la redirección de un navegador a un sitio comercial.

Tanto los virus y como el malware pueden operar de múltiples maneras. La terminología dista mucho de ser uniforme; aquí veremos una breve introducción a varios conceptos relacionados que podrían considerarse como malware de amenaza múltiple.

Un virus multipartito infecta de múltiples maneras. Normalmente, el virus multipartito es capaz de infectar varios tipos de archivos, de modo que la erradicación del virus debe ocuparse de todos los posibles sitios de infección.

Un ataque combinado utiliza múltiples métodos de infección o transmisión, para maximizar la velocidad de contagio y la gravedad del ataque. Algunos autores caracterizan un ataque combinado como un paquete que incluye múltiples tipos de malwares. Un ejemplo de ataque combinado es el ataque Nimda, erróneamente denominado simplemente gusano. Nimda utiliza cuatro métodos de distribución:

- Correo electrónico: Un usuario en un host vulnerable abre un archivo adjunto de correo electrónico infectado; Nimda busca direcciones de correo electrónico en el host y luego envía copias de sí mismo a esas direcciones.
- Recursos compartidos de Windows: Nimda escanea los hosts en busca de archivos compartidos de Windows no seguros; entonces puede utilizar NetBIOS86 como mecanismo de transporte para infectar archivos en ese host con la esperanza de que un usuario ejecute un archivo infectado, lo que activará Nimda en ese host.
- Servidores web: Nimda analiza los servidores web en busca de vulnerabilidades conocidas. Si encuentra un servidor vulnerable, intenta transferir una copia de sí mismo al servidor e infectar éste y sus archivos.

- Clientes web: Si un cliente web vulnerable visita un servidor web que ha sido infectado por Nimda, la estación de trabajo del cliente se infectará.

Así, Nimda tiene características de gusano, virus y código móvil. Los ataques combinados también pueden propagarse a través de otros servicios, como la mensajería instantánea y el intercambio de archivos entre pares.

Criptografía

Existe un gran número de defensas contra los ataques informáticos, que abarcan desde la metodología hasta la tecnología. La herramienta más amplia disponible para los diseñadores y usuarios de sistemas es la criptografía. La criptografía desempeña un papel importante en la seguridad de los sistemas operativos. Por ejemplo, algunos sistemas de archivos pueden cifrar todos los datos del disco, protocolos como IPSec pueden cifrar y/o firmar todos los paquetes de red, y la mayoría de los sistemas operativos codifican las contraseñas para evitar que los atacantes las recuperen.

En un computador aislado, el sistema operativo puede determinar de forma fiable el remitente y el destinatario de toda la comunicación entre procesos, ya que controla todos los canales de comunicación del computador. En una red de computadores, la situación es muy diferente. Un computador conectado a la red recibe bits desde esta sin que haya una forma inmediata y fiable de determinar qué máquina o aplicación ha enviado esos bits. Del mismo modo, el computador envía bits a la red sin saber quién podría recibirlos eventualmente. Además, tanto al enviar como al recibir, el sistema no tiene forma de saber si un espía ha escuchado la comunicación.

Normalmente, las direcciones de red se utilizan para inferir los posibles remitentes y receptores de los mensajes de red. Los paquetes de red llegan con una dirección de origen, como una dirección IP. Y cuando un computador envía un mensaje, nombra al destinatario especificando una dirección de destino. Sin embargo, para las aplicaciones en las que la seguridad es importante, nos buscamos problemas si suponemos que la dirección de origen o de destino de un paquete determina de forma fiable quién lo ha enviado o recibido. Un computador deshonesto puede enviar un mensaje con una dirección de origen falsificada, y numerosos computadores distintos al especificado por la dirección de destino pueden (y normalmente lo hacen) recibir un paquete. Por ejemplo, todos los routers en el camino hacia el destino también recibirán el paquete. Entonces, ¿cómo va a decidir un sistema operativo si concede una solicitud cuando no puede confiar en el origen de esta? ¿Y cómo va a proteger una solicitud o unos datos cuando no puede determinar quién recibirá la respuesta o el contenido del mensaje que envía por la red?

En general, se considera inviable construir una red de cualquier escala en la que se pueda confiar en las direcciones de origen y destino de los paquetes en

este sentido. Por tanto, la única alternativa es eliminar de algún modo la necesidad de confiar en la red. Este es el trabajo de la criptografía. De forma abstracta, la criptografía se utiliza para restringir los posibles remitentes y/o receptores de un mensaje. La criptografía moderna se basa en secretos llamados claves que se distribuyen selectivamente a los computadores de una red y se utilizan para procesar los mensajes. La criptografía permite al receptor de un mensaje verificar que éste ha sido creado por un computador que posee una determinada clave. Del mismo modo, un remitente puede codificar su mensaje para que sólo un computador con una determinada clave pueda descodificarlo. Sin embargo, a diferencia de las direcciones de red, las claves están diseñadas de tal manera que no es factible computacionalmente derivarlas de los mensajes que se utilizaron para generar o de cualquier otra información pública. Por lo tanto, proporcionan un medio mucho más fiable para limitar a los emisores y receptores de mensajes.

El propósito de la criptografía es tomar un mensaje o archivo, llamado *texto plano*, y cifrarlo en texto cifrado de tal manera que sólo las personas autorizadas sepan cómo convertirlo de nuevo en texto plano. Para todos los demás, el texto cifrado es sólo un montón de bits incomprensibles. Por extraño que pueda parecer a los principiantes en la materia, los algoritmos (funciones) de cifrado y descifrado deben ser siempre públicos. Intentar mantenerlos en secreto casi nunca funciona y da a las personas que intentan guardar los secretos una falsa sensación de seguridad. En el sector, esta táctica se denomina seguridad por oscuridad y sólo la emplean los aficionados a la seguridad. Curiosamente, en la categoría de aficionados también se encuentran muchas grandes corporaciones multinacionales que deberían saberlo mejor.

En cambio, el secreto depende de los parámetros de los algoritmos llamados claves. Si P es el archivo de texto plano, K es la clave de cifrado, C es el texto cifrado y E es el algoritmo de cifrado (es decir, la función), entonces $C = E(P, K)$. Esta es la definición de cifrado. Dice que el texto cifrado se obtiene utilizando el algoritmo de cifrado (conocido), E , con el texto plano, P , y la clave de cifrado (secreta), K , como parámetros. La idea de que todos los algoritmos deben ser públicos y el secreto debe residir exclusivamente en las claves se denomina principio de Kerckhoffs, formulado por el criptógrafo holandés del siglo XIX Auguste Kerckhoffs. Todos los criptógrafos serios suscriben esta idea.

Del mismo modo, $P = D(C, K)$ donde D es el algoritmo de descifrado y K es la clave de descifrado. Esto significa que, para recuperar el texto plano, P , a partir del texto cifrado, C , y la clave de descifrado, K , se ejecuta el algoritmo D con C y K como parámetros.

La criptografía es una herramienta poderosa, y su uso puede provocar conflictos. Algunos países prohíben su uso en determinadas formas o limitan la longitud de las claves. En otros se debate si los proveedores de tecnología (como los de los smartphones) deben proporcionar una puerta trasera a la criptografía

incluida, lo que permitiría a las fuerzas de seguridad eludir la privacidad que proporciona. Sin embargo, muchos observadores sostienen que las puertas traseras son una debilidad de seguridad intencionada que podría ser explotada por los atacantes o incluso mal utilizada por los gobiernos.

Por último, hay que tener en cuenta que la criptografía es un campo de estudio en sí mismo, con grandes y pequeñas complejidades y sutilezas cuyo estudio no está entre los objetivos del presente curso. Una discusión seria de la criptografía está más allá del alcance de este apunte. Aquí sólo hemos mencionado muy brevemente algunas de las inquietudes más importantes a las cuales la criptografía les proveerá de una respuesta para la administración de la seguridad de los sistemas operativos.

Autenticación de usuario

En la mayoría de los contextos de seguridad informática, la autenticación del usuario es el elemento fundamental y la principal línea de defensa. La autenticación del usuario es la base de la mayoría de los tipos de control de acceso y de la responsabilidad del usuario. Debemos tener presente que la autenticación de usuario es distinta de la autenticación de mensajes. La autenticación de mensajes es un procedimiento que permite a las partes comunicantes verificar que el contenido de un mensaje recibido no ha sido alterado y que la fuente es auténtica. Aquí nos ocuparemos exclusivamente de la autenticación de usuarios.

Los párrafos previos sobre la autenticación se centraban en mensajes y sesiones. ¿Pero qué pasa con los usuarios? Si un sistema no puede autenticar a un usuario, entonces autenticar que un mensaje proviene de ese usuario no tiene sentido. Por lo tanto, uno de los principales problemas de seguridad de los sistemas operativos es la autenticación de los usuarios. El sistema de protección depende de la capacidad de identificar los programas y procesos que se están ejecutando, lo que a su vez depende de la capacidad de identificar a cada usuario del sistema.

El Glosario de Seguridad de Internet define la autenticación de usuario como sigue:

- El proceso de verificación de una identidad reclamada por o para una entidad del sistema. Un proceso de autenticación consta de dos pasos:
 - Paso de identificación: Presentación de un identificador al sistema de seguridad. (Los identificadores deben asignarse cuidadosamente, porque las identidades autenticadas son la base de otros servicios de seguridad, como el servicio de control de acceso).
 - Paso de verificación: Presentar o generar información de autenticación que corrobore la vinculación entre la entidad y el identificador.

Por ejemplo, el usuario Jerónimo Almas podría tener el identificador de usuario JNMOLAS. Esta información debe almacenarse en cualquier servidor o sistema informático que Jerónimo desee utilizar y podría ser conocida por los administradores del sistema y otros usuarios. Un elemento típico de información de autenticación asociado a este identificador de usuario es una contraseña, que se mantiene en secreto (conocida sólo por Jerónimo y por el sistema). Si nadie es capaz de obtener o adivinar la contraseña de Jerónimo, entonces la combinación del ID de usuario de Jerónimo y la contraseña permite a los administradores establecer los permisos de acceso de Jerónimo y auditar su actividad. Como el ID de Jerónimo no es secreto, los usuarios del sistema pueden enviarle un correo electrónico, pero como su contraseña es secreta, nadie puede hacerse pasar por Jerónimo. En esencia, la identificación es el medio por el cual un usuario proporciona una identidad reclamada al sistema; la autenticación del usuario es el medio para establecer la validez del reclamo.

La forma más utilizada de autenticación es requerir que el usuario escriba un nombre de inicio de sesión y una contraseña. La protección mediante contraseñas es fácil de comprender y de implementar. La implementación más simple sólo mantiene una lista central de pares (nombre-inicio sesión, contraseña). El nombre de inicio de sesión que se introduce se busca en la lista y la contraseña introducida se compara con la contraseña almacenada. Si coinciden, se permite al usuario que inicie sesión; en caso contrario, se rechaza. Tal vez no haya necesidad de decir que mientras se escribe una contraseña en la computadora, ésta no debe mostrar los caracteres escritos, para evitar que alguien cercano al monitor los vea.

En Windows, a medida que se escribe cada carácter aparece un asterisco. En UNIX no aparece ningún carácter a medida que se escribe la contraseña. Estos esquemas tienen distintas propiedades. El esquema de Windows puede servir para que los usuarios distraídos vean fácilmente cuántos caracteres han escrito en cierto momento, pero esto también divulga la longitud de la contraseña a los fisgones. Desde la perspectiva de seguridad, el silencio es oro.

Como observación adicional sobre el inicio de sesión, la mayoría de las notebooks, o tablets, se configuran para requerir un nombre de usuario y una contraseña, de manera que su contenido esté protegido en caso de que se pierdan o sean robadas. Aunque eso es mejor que nada, no es mucho mejor que nada. Cualquiera que se apodere de la notebook puede iniciarla y de inmediato ir al programa de configuración del BIOS, oprimiendo SUPR, F8 o alguna otra tecla específica para el BIOS (que por lo general aparece en la pantalla) antes de que se inicie el sistema operativo. Una vez ahí, puede modificar la secuencia de arranque para que la computadora arranque desde una memoria USB antes de intentar con el disco duro. Después, el saboteador inserta una memoria USB que contenga un sistema operativo completo y arranca la computadora desde ahí. Una vez en ejecución el disco duro se puede montar (en UNIX) o utilizar

como la unidad D: (Windows). Para evitar esta situación, la mayoría de los BIOS permiten que el usuario proteja el programa de configuración con contraseña, de manera que sólo el propietario pueda cambiar la secuencia de arranque.

Los usuarios normalmente se identifican, pero ¿cómo determinar si la identidad de un usuario es auténtica? Generalmente, la autenticación del usuario se basa en uno o más de los cuatro medios generales que existen para autenticar la identidad de un usuario, los que pueden utilizarse solos o combinados:

- Algo que la persona conoce: por ejemplo, una contraseña, un número de identificación personal (PIN) o las respuestas a un conjunto de preguntas preestablecidas.
- Algo que el individuo posee: Por ejemplo, tarjetas electrónicas, tarjetas inteligentes o llaves físicas. Este tipo de autenticador se denomina token.
- Algo que el individuo es (biometría estática): Los ejemplos incluyen el reconocimiento por huella dactilar, retina y cara.
- Algo que el individuo hace (biometría dinámica): Los ejemplos incluyen el reconocimiento por el patrón de voz, las características de la escritura a mano y el ritmo de tecleo.

Todos estos métodos, correctamente implementados y utilizados, pueden proporcionar una autenticación segura del usuario. Sin embargo, cada método tiene problemas. Un adversario puede ser capaz de adivinar o robar una contraseña. Del mismo modo, un adversario puede ser capaz de falsificar o robar un token. Un usuario puede olvidar una contraseña o perder un token. Además, la gestión de la información de las contraseñas y los tokens en los sistemas y la protección de dicha información en los sistemas conlleva una importante carga administrativa. Con respecto a los autenticadores biométricos, hay una serie de problemas, incluyendo el tratamiento de falsos positivos y falsos negativos, la aceptación del usuario, el costo y la conveniencia.

Autenticación basada en contraseñas

Una línea de defensa muy utilizada contra los intrusos es el sistema de contraseñas. Prácticamente todos los sistemas multiusuario, los servidores basados en la red, los sitios de comercio electrónico basados en la web y otros servicios similares requieren que un usuario proporcione no sólo un nombre o identificador (ID) sino también una contraseña. Es el método más común para autenticar la identidad de un usuario. Cuando el usuario se identifica por su ID de usuario o nombre de cuenta, se le pide una contraseña. El sistema compara la contraseña con una contraseña previamente almacenada para ese ID de usuario, mantenida en un archivo de contraseñas del sistema. La contraseña sirve para autenticar el ID de la persona que se conecta al sistema. A su vez, el ID proporciona seguridad de las siguientes maneras:

- El ID determina si el usuario está autorizado a acceder a un sistema. En algunos sistemas, sólo se permite el acceso a aquellos que ya tienen un ID registrado en el sistema.
- El ID determina los privilegios concedidos al usuario. Algunos usuarios pueden tener un estatus de supervisor o superusuario que les permite leer archivos y realizar funciones especialmente protegidas por el sistema operativo. Algunos sistemas tienen cuentas de invitado o anónimas, y los usuarios de estas cuentas tienen privilegios más limitados que otros.
- El ID se utiliza en lo que se denomina control de acceso discrecional. Por ejemplo, al enumerar los ID de los demás usuarios, un usuario puede concederles permiso para leer los archivos que le pertenecen.

Si la contraseña proporcionada por el usuario coincide con la contraseña almacenada en el sistema, el sistema asume que el propietario de la cuenta está accediendo a ella.

Las contraseñas se utilizan a menudo para proteger objetos en el sistema informático, a falta de esquemas de protección más completos. Pueden considerarse un caso especial de las claves o de las capacidades. Por ejemplo, se puede asociar una contraseña a cada recurso (como un archivo). Cada vez que se solicita el uso del recurso, hay que dar la contraseña. Si la contraseña es correcta, se concede el acceso. Diferentes contraseñas pueden estar asociadas a diferentes derechos de acceso. Por ejemplo, se pueden utilizar diferentes contraseñas para leer archivos, añadir archivos y actualizar archivos.

En la práctica, la mayoría de los sistemas sólo requieren una contraseña para que un usuario obtenga todos sus derechos. Aunque teóricamente más contraseñas serían más seguras, estos sistemas no suelen implementarse debido al clásico equilibrio entre seguridad y comodidad. Si la seguridad hace que algo resulte incómodo, la seguridad se suele eludir o sortear de alguna manera.

Debilidades de las contraseñas

Las contraseñas son muy comunes porque son fáciles de entender y utilizar. Desgraciadamente, las contraseñas a menudo pueden ser adivinadas, expuestas accidentalmente, leídas por un intruso o transferidas ilegalmente de un usuario autorizado a otro no autorizado.

A menudo, los crackers entran simplemente conectándose al computador objetivo (por ejemplo, a través de Internet) y probando muchas combinaciones (nombre de usuario, contraseña) hasta que encuentran una que funcione. Hay tres formas habituales de adivinar una contraseña. Una forma es que el intruso (ya sea humano o programa) conozca al usuario o tenga información sobre él. Con demasiada frecuencia, la gente utiliza información obvia (como los nombres de sus gatos o familiares) como sus contraseñas. Otra forma es utilizar la fuerza bruta, probando la enumeración, o todas las combinaciones posibles

de caracteres válidos para la contraseña (letras, números y puntuación en algunos sistemas), hasta encontrar la contraseña. Las contraseñas cortas son especialmente vulnerables a este método.

Por ejemplo, una contraseña de cuatro caracteres ofrece sólo 10.000 variaciones. En promedio, si se adivinan 5.000 veces se obtendrá una respuesta correcta. Un programa que pudiera probar una contraseña cada milisegundo sólo tardaría unos 5 segundos en adivinar una contraseña de cuatro caracteres. La enumeración tiene menos éxito cuando los sistemas permiten contraseñas más largas que incluyen tanto letras mayúsculas como minúsculas, junto con números y todos los caracteres de puntuación. Por supuesto, los usuarios deben aprovechar el amplio espacio de las contraseñas y no deben, por ejemplo, utilizar sólo letras minúsculas. El tercer método habitual son los ataques de diccionario, en los que se prueban todas las palabras, variaciones de palabras y contraseñas comunes.

Además de ser adivinadas, las contraseñas pueden quedar expuestas como resultado de la vigilancia visual o electrónica. Un intruso puede mirar por encima del hombro de un usuario cuando éste se está conectando y puede aprender la contraseña fácilmente observando el teclado. Por otra parte, cualquier persona con acceso a la red en la que reside un computador puede añadir sin problemas un monitor de red, lo que le permite husmear, o ver, todos los datos que se transfieren en la red, incluidos los identificadores de usuario y las contraseñas. La encriptación del flujo de datos que contiene la contraseña resuelve este problema. Sin embargo, incluso un sistema de este tipo podría tener contraseñas robadas. Por ejemplo, si se utiliza un archivo para contener las contraseñas, podría ser copiado para su análisis fuera del sistema. O considere un programa troyano instalado en el sistema que capture cada pulsación de tecla antes de enviarla a la aplicación. Otro método habitual para hacerse con las contraseñas, especialmente las de las tarjetas de débito, consiste en instalar dispositivos físicos en los que se utilizan las claves y grabar lo que hace el usuario, por ejemplo, un skimmer en un cajero automático o un dispositivo instalado entre el teclado y el computador.

La exposición es un problema especialmente grave si la contraseña está escrita en un lugar donde puede leerse o perderse. Algunos sistemas obligan a los usuarios a seleccionar contraseñas difíciles de recordar o largas, o a cambiarlas con frecuencia, lo que puede hacer que el usuario registre la contraseña o la reutilice. Como resultado, estos sistemas proporcionan mucha menos seguridad que los sistemas que permiten a los usuarios seleccionar contraseñas fáciles.

El último tipo de compromiso de la contraseña, la transferencia ilegal, es el resultado de la naturaleza humana. La mayoría de las instalaciones de computadores tienen una regla que prohíbe a los usuarios compartir cuentas. Esta regla se implementa a veces por razones de contabilidad, pero a menudo tiene como objetivo mejorar la seguridad. Por ejemplo, supongamos que un ID

de usuario es compartido por varios usuarios, y se produce un fallo de seguridad desde ese ID de usuario. Es imposible saber quién estaba usando el ID en el momento en que se produjo la ruptura o incluso si el usuario era uno autorizado. Con un usuario por ID de usuario, cualquier usuario puede ser interrogado directamente sobre el uso de la cuenta; además, el usuario podría notar algo diferente en la cuenta y detectar la ruptura. A veces, los usuarios infringen las normas de uso compartido de cuentas para ayudar a sus amigos o para eludir la contabilidad, y este comportamiento puede dar lugar a que usuarios no autorizados, posiblemente perjudiciales, accedan al sistema.

Las contraseñas pueden ser generadas por el sistema o seleccionadas por un usuario. Las contraseñas generadas por el sistema pueden ser difíciles de recordar, por lo que los usuarios pueden escribirlas. Sin embargo, como se ha mencionado, las contraseñas seleccionadas por el usuario suelen ser fáciles de adivinar (el nombre del usuario o su coche favorito, por ejemplo). Algunos sistemas comprueban la facilidad de adivinar o descifrar una contraseña propuesta antes de aceptarla. Algunos sistemas también envejecen las contraseñas, obligando a los usuarios a cambiarlas a intervalos regulares (cada tres meses, por ejemplo). Este método tampoco es infalible, ya que los usuarios pueden alternar fácilmente entre dos contraseñas. La solución, tal y como se implementa en algunos sistemas, es registrar un historial de contraseñas para cada usuario. Por ejemplo, el sistema podría registrar las últimas N contraseñas y no permitir su reutilización.

Se pueden utilizar varias variantes de estos esquemas de contraseñas simples. Por ejemplo, la contraseña puede cambiarse con mayor frecuencia. En el extremo, la contraseña se cambia de sesión a sesión. Al final de cada sesión se selecciona una nueva contraseña (ya sea por el sistema o por el usuario), y esa contraseña debe utilizarse para la siguiente sesión. En este caso, aunque la contraseña sea utilizada por una persona no autorizada, ésta sólo podrá utilizarla una vez. Cuando el usuario legítimo intenta utilizar una contraseña ahora inválida en la siguiente sesión, descubre la violación de la seguridad. Entonces puede tomar medidas para reparar la seguridad violada.

Contraseñas cifradas

Uno de los problemas de todos estos enfoques es la dificultad de mantener la contraseña en secreto dentro del computador. ¿Cómo puede el sistema almacenar una contraseña de forma segura y a la vez permitir su uso para la autenticación cuando el usuario presenta su contraseña? El sistema UNIX utiliza un cifrado (hash) seguro y un valor denominado *salt* para evitar la necesidad de mantener su lista de contraseñas en secreto. Dado que la contraseña está cifrada en lugar de encriptada, es imposible que el sistema descifre el valor almacenado y determine la contraseña original. Este esquema se encuentra en

prácticamente todas las variantes de UNIX, así como en otros sistemas operativos. Se emplea el siguiente procedimiento.

Para cargar una nueva contraseña en el sistema, el usuario selecciona o se le asigna una contraseña. Esta contraseña se combina con el valor salt de longitud fija. En las implementaciones más antiguas, este valor está relacionado con el momento en que se asigna la contraseña al usuario. Las implementaciones más recientes utilizan un número pseudoaleatorio o aleatorio. La contraseña y el valor salt sirven como entradas a un algoritmo de cifrado (hash) para producir un código cifrado de longitud fija. El algoritmo de cifrado está diseñado para que se ejecute lentamente para frustrar los ataques. La contraseña cifrada se almacena, junto con una copia en texto plano del valor salt, en el archivo de contraseñas para el correspondiente ID de usuario. El método de la contraseña cifrada ha demostrado ser seguro contra una variedad de ataques criptoanalíticos.

Cuando un usuario intenta conectarse a un sistema UNIX, proporciona un ID y una contraseña. El sistema operativo utiliza el ID para indexar el archivo de contraseñas y recuperar el valor salt en texto plano y la contraseña cifrada. El valor salt y la contraseña proporcionada por el usuario se utilizan como entrada a la rutina de cifrado. Si el resultado coincide con el valor almacenado, se acepta la contraseña. El valor salt cumple tres funciones:

- Evita que las contraseñas duplicadas sean visibles en el archivo de contraseñas. Incluso si dos usuarios eligen la misma contraseña, a esas contraseñas se les asignarán diferentes valores de salt. Por lo tanto, las contraseñas con hash de los dos usuarios serán diferentes.
- Esto aumenta en gran medida la dificultad de los ataques de diccionario fuera de línea. Para un salt de longitud b bits, el número de contraseñas posibles se incrementa en un factor de 2^b , aumentando la dificultad de adivinar una contraseña en un ataque de diccionario.
- Resulta casi imposible averiguar si una persona con contraseñas en dos o más sistemas ha utilizado la misma contraseña en todos ellos.

Para ver el segundo punto, consideremos la forma en que funcionaría un ataque de diccionario fuera de línea. El atacante obtiene una copia del archivo de contraseñas. Supongamos primero que el valor salt no se utiliza. El objetivo del atacante es adivinar una única contraseña. Para ello, el atacante somete un gran número de contraseñas probables a la función hash. Si alguna de las adivinanzas coincide con uno de los hashes del archivo, entonces el atacante ha encontrado una contraseña que está en el archivo. Pero frente al esquema UNIX, el atacante debe tomar cada conjetura y someterla a la función hash una vez por cada valor de sal en el archivo del diccionario, multiplicando el número de conjeturas que deben ser comprobadas.

Hay dos amenazas para el esquema de contraseñas de UNIX. En primer lugar, un usuario puede obtener acceso en una máquina utilizando una cuenta de invitado o por algún otro medio y luego ejecutar un programa de adivinación de contraseñas, llamado password cracker, en esa máquina. El atacante debería ser capaz de comprobar muchos miles de contraseñas posibles con poco consumo de recursos. En segundo lugar, si un adversario es capaz de obtener una copia del archivo de contraseñas, puede ejecutar un programa de descifrado en otra máquina cuando lo desee. Esto permite al adversario comprobar millones de contraseñas posibles en un periodo de tiempo razonable.

Ante este hecho, para obtener una seguridad adicional, algunas versiones modernas de UNIX hacen que el archivo de contraseñas sea ilegible, pero proporcionan un programa para buscar entradas en base a la petición, y agregan el suficiente retraso como para atrasar de manera considerable a cualquier atacante. En general, la combinación de usar un número salt con el archivo de contraseñas y hacerlo ilegible, excepto de manera indirecta (y lento), puede soportar la mayoría de los ataques.

Contraseñas de un solo uso

La mayoría de los administradores exhortan a sus usuarios para que cambien sus contraseñas una vez al mes. La mayoría de los usuarios hacen caso omiso. Lo más extremo es cambiar la contraseña en cada inicio de sesión; a estas contraseñas se les conoce como contraseñas de un solo uso.

Para evitar los problemas de la detección de contraseñas y las miradas de los curiosos por encima del hombro, un sistema puede utilizar un conjunto de contraseñas emparejadas. Cuando se inicia una sesión, el sistema selecciona aleatoriamente y presenta una parte de un par de contraseñas; el usuario debe proporcionar la otra parte. En este sistema, el usuario es desafiado y debe responder con la respuesta correcta a ese desafío.

Este enfoque puede generalizarse al uso de un algoritmo como contraseña. En este esquema, el sistema y el usuario comparten una contraseña simétrica. La contraseña pw nunca se transmite por un medio que permita su exposición. Más bien, la contraseña se utiliza como entrada a una función, junto con un desafío ch presentado por el sistema. El usuario calcula entonces la función $H(pw, ch)$. El resultado de esta función se transmite como autenticador al computador. Como el computador también conoce pw y ch, puede realizar el mismo cálculo. Si los resultados coinciden, el usuario queda autenticado. La próxima vez que el usuario necesite autenticarse, se genera otra ch y se siguen los mismos pasos. Esta vez, el autenticador es diferente. Estas contraseñas algorítmicas no son susceptibles de ser reutilizadas. Es decir, un usuario puede escribir una contraseña y ninguna entidad que la intercepte podrá reutilizarla. Este sistema de contraseñas de un solo uso es una de las pocas formas de evitar la autenticación incorrecta debido a la exposición de la contraseña.

Los sistemas de contraseñas de un solo uso se implementan de varias maneras. Las implementaciones comerciales utilizan calculadoras de hardware con una pantalla o una pantalla y un teclado numérico. Estas calculadoras suelen tener la forma de una tarjeta de crédito, un llavero o un dispositivo USB. El software que se ejecuta en computadores o smartphones proporciona al usuario $H(pw, ch)$; pw puede ser introducido por el usuario o generado por la calculadora en sincronización con el computador. A veces, pw es sólo un número de identificación personal (PIN). La salida de cualquiera de estos sistemas muestra la contraseña de un solo uso. Un generador de contraseñas de un solo uso que requiere la introducción de datos por parte del usuario implica una autenticación de dos factores. En este caso se necesitan dos tipos diferentes de componentes, por ejemplo, un generador de contraseñas de un solo uso que genere la respuesta correcta sólo si el PIN es válido. La autenticación de dos factores ofrece una protección de autenticación mucho mejor que la autenticación de un solo factor porque requiere *algo que se tiene* además de *algo que se sabe*.

Autenticación de reto-respuesta

Una variación en la idea de las contraseñas es hacer que cada nuevo usuario proporcione una larga lista de preguntas y respuestas que posteriormente se almacenan en el servidor en forma segura (por ejemplo, en formato cifrado). Las preguntas se deben elegir de tal forma que el usuario no tenga que anotarlas. Algunas preguntas posibles son:

- ¿Quién es la hermana de Tabares?
- ¿En qué barrio se encontraba su escuela secundaria?
- ¿Qué enseñaba el profesor Gutiérrez?

Al momento de iniciar sesión, el servidor hace una de estas preguntas al azar y comprueba la respuesta. No obstante, para que este esquema sea práctico se necesitan muchos pares de pregunta - respuesta.

La autenticación reto-respuesta es otra variación. Cuando se utiliza, el usuario elige un algoritmo al registrarse como usuario, por ejemplo, x^2 . Cuando el usuario inicia sesión, el servidor le envía un argumento; por ejemplo, un 10, en cuyo caso el usuario escribe 100. El algoritmo puede ser distinto en la mañana y en la tarde, en distintos días de la semana, y así en lo sucesivo.

Si el dispositivo del usuario tiene un poder de cómputo destacable, entonces se puede utilizar una forma más poderosa de reto-respuesta. El usuario selecciona por adelantado una clave secreta k , la cual en un principio se lleva al sistema servidor en forma manual. También se mantiene una copia (en forma segura) en la computadora del usuario. Al momento de iniciar sesión, el servidor envía un número aleatorio r a la computadora del usuario, que a su vez calcula $f(r, k)$ y envía el resultado de vuelta, en donde f es una función conocida

públicamente. Después el servidor realiza el cálculo y comprueba si el resultado que recibió de la computadora del usuario coincide con el resultado de su cálculo. La ventaja de este esquema en comparación con una contraseña es que, incluso si una persona que interviene los cables de red ve y registra todo el tráfico en ambas direcciones, no aprenderá nada que le ayude la próxima vez. Desde luego que la función f tiene que ser lo bastante complicada como para que no se pueda deducir el valor de k , aun si se tiene un conjunto extenso de observaciones. Las funciones de hash criptográficas son buenas opciones, en donde el argumento es la función XOR de r y k . Se sabe que es difícil invertir estas funciones.

Autenticación basada en tokens

Los objetos que posee un usuario con el fin de autenticarse se denominan tokens. En esta subsección, examinamos dos tipos de tokens muy utilizados; se trata de tarjetas que tienen la apariencia y el tamaño de las tarjetas bancarias.

- **Tarjetas de memoria.** Las tarjetas de memoria pueden almacenar, pero no procesar datos. La tarjeta más común de este tipo es la tarjeta bancaria con una banda magnética en el reverso. La banda magnética sólo puede almacenar un simple código de seguridad, que puede ser leído (y desgraciadamente reprogramado) por un lector de tarjetas barato. También hay tarjetas de memoria que incluyen una memoria electrónica interna. Las tarjetas de memoria pueden utilizarse solas para el acceso físico, por ejemplo, a una habitación de hotel. Para la autenticación de usuarios de computadores, estas tarjetas suelen utilizarse con algún tipo de contraseña o número de identificación personal (PIN). Una aplicación típica es un cajero automático (ATM).

La tarjeta de memoria, cuando se combina con un PIN o una contraseña, proporciona una seguridad significativamente mayor que una contraseña sola. Un adversario debe obtener la posesión física de la tarjeta (o ser capaz de duplicarla) y además debe conocer el PIN. Entre los posibles inconvenientes están los siguientes:

- *Requiere un lector especial:* Esto aumenta el costo del uso del token y crea la necesidad de mantener la seguridad del hardware y el software del lector.
- *Pérdida del token:* La pérdida de un token impide temporalmente a su propietario acceder al sistema. Por lo tanto, la sustitución del token perdido supone un costo administrativo. Además, si el token es encontrado, robado o falsificado, un adversario sólo necesita determinar el PIN para obtener un acceso no autorizado.
- *Insatisfacción del usuario:* Aunque a los usuarios no les cueste aceptar el uso de una tarjeta de memoria para acceder a los cajeros automáticos,

su uso para acceder al computador seguramente será considerado inconveniente.

- **Tarjetas inteligentes.** Hay una gran variedad de dispositivos que pueden considerarse tokens inteligentes. Se pueden clasificar en tres dimensiones que no se excluyen mutuamente:
 - *Características físicas:* Los tokens inteligentes incluyen un microprocesador integrado. Las tokens inteligentes que se parecen a una tarjeta bancaria se denominan tarjetas inteligentes. Los tokens inteligentes pueden parecerse a calculadoras, llaves u otros objetos pequeños y portátiles.
 - *Interfaz:* Las interfaces manuales incluyen un teclado y una pantalla para la interacción entre el ser humano y la ficha. Los tokens inteligentes con una interfaz electrónica se comunican con un lector/grabador compatible.
 - *Protocolo de autenticación:* Los tokens inteligentes tienen como objetivo proporcionar un medio para la autenticación del usuario. Podemos clasificar los protocolos de autenticación utilizados con los tokens inteligentes en tres categorías:
 - ⊗ *Estático:* Con un protocolo estático, el usuario se autentifica ante el token y luego el token autentifica al usuario ante el computador. La segunda mitad de este protocolo es similar al funcionamiento de un token de memoria.
 - ⊗ *Generador dinámico de contraseñas:* En este caso, el token genera una contraseña única periódicamente (por ejemplo, cada minuto). A continuación, esta contraseña se introduce en el sistema informático para su autenticación, ya sea manualmente por el usuario o electrónicamente a través del token. El token y el sistema informático deben inicializarse y mantenerse sincronizados para que el computador conozca la contraseña vigente para este token.
 - ⊗ *Reto-respuesta:* En este caso, el sistema informático genera un desafío, como una cadena de números aleatorios. Las tokens inteligentes generan una respuesta basada en el reto. Por ejemplo, se podría utilizar la criptografía de clave pública y el token podría cifrar la cadena de desafío con la clave privada del token.

Para la autenticación del usuario ante el computador, la categoría más importante de tokens inteligentes es la tarjeta inteligente, que tiene la apariencia de una tarjeta de crédito, tiene una interfaz electrónica y puede utilizar cualquiera de los tipos de protocolos que se acaban de describir. El resto de esta sección trata sobre las tarjetas inteligentes.

Una tarjeta inteligente contiene en su interior un microprocesador completo, incluyendo procesador, memoria y puertos de E/S. Algunas

versiones incorporan un circuito de coprocesamiento especial para la operación criptográfica con el fin de acelerar la tarea de codificación y decodificación de mensajes o de generar firmas digitales para validar la información transferida. En algunas tarjetas, los puertos de E/S son directamente accesibles por un lector compatible mediante contactos eléctricos expuestos. Otras tarjetas se basan en cambio en una antena integrada para la comunicación inalámbrica con el lector.

Autenticación biométrica

Un sistema de autenticación biométrica intenta autenticar a un individuo basándose en sus características físicas únicas. Estas incluyen características estáticas, como las huellas dactilares, la geometría de la mano, las características faciales y los patrones de la retina y el iris; y características dinámicas, como la huella vocal y la firma. En esencia, la biometría se basa en el reconocimiento de patrones. En comparación con las contraseñas y los tokens, la autenticación biométrica es técnicamente compleja y cara, aunque se utiliza en una serie de aplicaciones específicas como herramienta estándar para la autenticación de usuarios en sistemas de computación.

Un sistema biométrico típico consta de dos partes: el registro y la identificación. Durante el registro, se miden las características del usuario y se digitalizan los resultados. A continuación, se extraen las características significativas y se almacenan en un registro asociado al usuario. El registro puede guardarse en una base de datos central (por ejemplo, para iniciar sesión en un computador remoto), o almacenarse en una tarjeta inteligente que el usuario lleva consigo y que inserta en un lector remoto (por ejemplo, en un cajero automático).

La otra parte es la identificación. El usuario se presenta y proporciona un nombre de usuario. Entonces el sistema vuelve a realizar la medición. Si los nuevos valores coinciden con los muestreados en el momento de la inscripción, se acepta el inicio de sesión; en caso contrario, se rechaza. El nombre de usuario es necesario porque las mediciones nunca son exactas, por lo que es difícil indexarlas y luego buscar en el índice. Además, dos personas pueden tener las mismas características, por lo que exigir que las características medidas coincidan con las de un usuario concreto es más fuerte que exigir que coincidan con las de cualquier usuario.

La característica elegida debe tener la suficiente variabilidad como para que el sistema pueda distinguir entre muchas personas sin error. Por ejemplo, el color del pelo no es un buen indicador porque demasiadas personas comparten el mismo color. Además, la característica no debe variar con el tiempo y en algunas personas el color del pelo no tiene esta propiedad. Del mismo modo, la voz de una persona puede ser diferente debido a un resfriado y la cara puede tener un aspecto diferente debido a la barba o al maquillaje no presente en el

momento de la inscripción. Dado que las muestras posteriores nunca van a coincidir exactamente con los valores de la inscripción, los diseñadores del sistema deben decidir la calidad de la coincidencia para que sea aceptada. Tienen que decidir si es peor rechazar a un usuario legítimo de vez en cuando o dejar que un impostor entre de vez en cuando. Un sitio de comercio electrónico podría decidir que rechazar a un cliente fiel podría ser peor que aceptar un pequeño fraude, mientras que un sitio de armas nucleares podría decidir que negar el acceso a un empleado genuino era mejor que dejar entrar a extraños al azar dos veces al año.

Hay varios tipos de características físicas en uso o en estudio para la autenticación de usuarios. Las más comunes son las siguientes:

- **Características faciales:** Las características faciales son el medio más común de identificación entre humanos; por lo tanto, es natural considerarlas para la identificación por computador. El enfoque más habitual es definir las características basándose en la ubicación y la forma relativas de los rasgos faciales clave, como los ojos, las cejas, la nariz, los labios y la forma de la barbilla. Un enfoque alternativo es utilizar una cámara de infrarrojos para producir un termograma facial que se correlacione con el sistema vascular subyacente en el rostro humano.
- **Huellas dactilares:** Las huellas dactilares se han utilizado como medio de identificación durante siglos, y el proceso se ha sistematizado y automatizado sobre todo con fines policiales. Una huella dactilar es el patrón de crestas y surcos en la superficie de la yema del dedo y se cree que las huellas dactilares son únicas en toda la población humana.

Los lectores de huellas dactilares se han vuelto precisos y rentables. Estos dispositivos leen los patrones de las crestas de los dedos y los convierten en una secuencia de números. Con el tiempo, pueden almacenar un conjunto de secuencias para ajustarse a la ubicación del dedo en la almohadilla de lectura y otros factores. El software puede entonces escanear un dedo en la almohadilla y comparar sus características con estas secuencias almacenadas para determinar si coinciden. Por supuesto, varios usuarios pueden tener perfiles almacenados, y el escáner puede diferenciar entre ellos. En la práctica, los sistemas automatizados de reconocimiento y comparación de huellas dactilares extraen una serie de características de la huella dactilar para almacenarlas como un sustituto numérico del patrón completo de la huella dactilar.

Un esquema de autenticación de dos factores muy preciso puede consistir en requerir una contraseña, así como un nombre de usuario y el escaneo de la huella dactilar. Si esta información está encriptada en tránsito, el sistema puede ser muy resistente a la suplantación o a los ataques de repetición.

La autenticación multifactorial es aún mejor. Pensemos en lo sólida que puede ser la autenticación con un dispositivo USB que debe conectarse al sistema, un PIN y un escáner de huellas dactilares. Salvo por el hecho de tener que colocar el dedo en una almohadilla y conectar el USB al sistema, este método de autenticación no es menos cómodo que el que utiliza contraseñas normales. Sin embargo, hay que recordar que la autenticación fuerte por sí misma no es suficiente para garantizar la identificación del usuario. Una sesión autenticada puede ser secuestrada si no está cifrada.

- **Geometría de la mano:** Los sistemas de geometría de la mano identifican las características de la mano, incluyendo la forma y la longitud y anchura de los dedos.
- **Patrón de la retina:** El patrón formado por las venas bajo la superficie de la retina es único y, por tanto, adecuado para la identificación. Un sistema biométrico retiniano obtiene una imagen digital del patrón retiniano proyectando un haz de luz visual o infrarroja de baja intensidad en el ojo.
- **Reconocimiento del iris:** Otra característica física única es la estructura detallada del iris. El sujeto sólo tiene que mirar a una cámara, a una distancia de hasta 1 metro, que fotografía los ojos del sujeto, extrae ciertas características realizando lo que se llama una transformación de ondículas de Gabor, y comprime los resultados en 256 bytes. Esta cadena se compara con el valor obtenido en el momento de la inscripción, y si la distancia de Hamming² está por debajo de algún umbral crítico, la persona queda autenticada.

Cualquier técnica que se base en imágenes está sujeta a la suplantación. Por ejemplo, una persona podría acercarse al equipo, por ejemplo, la cámara de un cajero automático, con unas gafas oscuras a las que se adjuntaran fotografías de los ojos de otra persona. Al fin y al cabo, si la cámara del cajero puede tomar una buena foto del iris a 1 metro, otras personas también pueden hacerlo, y a distancias mayores utilizando teleobjetivos. Por esta razón, pueden ser necesarias contramedidas como hacer que la cámara dispare un flash, no con fines de iluminación, sino para ver si la pupila se contrae en respuesta o para ver si el temido efecto de ojos rojos aparece en la foto con flash, pero está ausente cuando no se usa el flash. El aeropuerto de Ámsterdam lleva utilizando la tecnología de reconocimiento del iris desde 2001 para que los viajeros frecuentes puedan saltarse la cola normal de inmigración.

- **Firma:** Una técnica algo diferente es el análisis de firmas. Cada individuo tiene un estilo de escritura único, y esto se refleja especialmente en la firma, que suele ser una secuencia escrita con frecuencia. El usuario firma

² La distancia de Hamming entre dos cadenas de bits es el número mínimo de cambios necesarios para transformar una en otra.

su nombre con un bolígrafo especial conectado al computador, y éste lo compara con una muestra conocida almacenada en línea o en una tarjeta inteligente. Sin embargo, varias muestras de firmas de un mismo individuo no serán idénticas. Esto complica la tarea de desarrollar una representación computarizada de la firma que pueda ser comparada con futuras muestras.

Por ello resulta mejor no comparar la firma, sino comparar los movimientos del bolígrafo y la presión ejercida al escribirla. Un buen falsificador puede ser capaz de copiar la firma, pero no tendrá ni idea del orden exacto en que se hicieron los trazos o a qué velocidad y qué presión.

- **La voz:** Un esquema que depende de un hardware especial mínimo es la biometría de voz. Todo lo que se necesita es un micrófono (o incluso un teléfono); el resto es software. Mientras que el estilo de la firma de un individuo refleja no sólo los atributos físicos únicos del escritor, sino también el hábito de escritura que ha desarrollado, los patrones de voz están más estrechamente ligados a las características físicas y anatómicas del hablante. No obstante, sigue habiendo una variación de una muestra a otra a lo largo del tiempo del mismo hablante, lo que complica la tarea de reconocimiento biométrico.

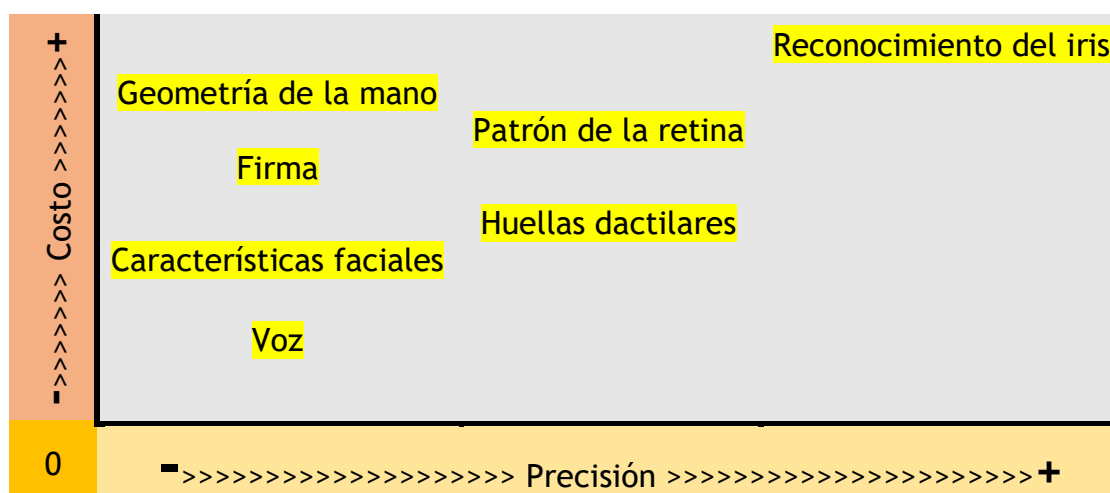
A diferencia de los sistemas de reconocimiento de voz, que sólo tratan de determinar lo que dice el interlocutor, los sistemas de identificación por voz tratan de determinar quién es el interlocutor. Algunos sistemas sólo requieren que el usuario diga una contraseña secreta, pero estos pueden ser derrotados por un espía que pueda grabar las contraseñas y reproducirlas más tarde. Los sistemas más avanzados dicen algo al usuario y le piden que lo repita, con textos diferentes para cada inicio de sesión. Algunas empresas están empezando a utilizar la identificación por voz para aplicaciones como la compra a domicilio por teléfono, ya que la identificación por voz está menos sujeta al fraude que el uso de un código PIN para identificarse. El reconocimiento de voz puede combinarse con otros elementos biométricos, como el reconocimiento facial, para mejorar la precisión.

Podríamos seguir analizando más tipos de características físicas, pero otros dos ejemplos nos ayudarán a aclarar un punto importante. Al parecer, algunos investigadores han desarrollado sistemas de reconocimiento de olores que podrían utilizarse como biométricos. Supongamos que alguien consigue un pequeño dispositivo capaz de hacer un reconocimiento de olores instantáneo, proporcionando así una identificación infalible. Cada computador podría estar equipado con uno de estos dispositivos. Este podría ser un sistema absolutamente irrompible, pero probablemente tendría un problema bastante serio de aceptación por parte de los usuarios. También es potencialmente problemático un sistema compuesto por una diminuta aguja y un pequeño espectrógrafo. Se pediría al usuario que presionara su pulgar contra la aguja, extrayendo así una gota de sangre para el análisis espectrográfico. Hasta ahora,

nadie ha publicado nada al respecto, pero hay trabajos sobre la obtención de imágenes de los vasos sanguíneos como biometría.

Nuestro punto es que cualquier esquema de autenticación debe ser psicológicamente aceptable para la comunidad de usuarios. Las mediciones de la longitud de los dedos probablemente no causen ningún problema, pero incluso algo tan poco intrusivo como el almacenamiento de las huellas dactilares en línea puede ser inaceptable para muchas personas porque asocian las huellas dactilares con los delincuentes. No obstante, Apple introdujo la tecnología en el iPhone 5S.

La siguiente tabla ofrece una visión aproximada entre el costo y la precisión de estas medidas biométricas.



Finalmente diremos que el concepto de precisión no se aplica a los esquemas de autenticación de usuarios que utilizan tarjetas inteligentes o contraseñas. Por ejemplo, si un usuario introduce una contraseña, ésta coincide exactamente con la que se espera para ese usuario o no. En el caso de los parámetros biométricos, el sistema debe determinar en qué medida una característica biométrica presentada coincide con una característica almacenada.

Implementación de defensas

Con problemas merodeando por todos lados, ¿hay alguna esperanza de que los sistemas puedan ser seguros? En realidad, sí la hay, al igual que existen innumerables amenazas para la seguridad de los sistemas y las redes, hay muchas soluciones de seguridad, y a continuación analizaremos algunas de las formas en que se pueden diseñar e implementar sistemas para incrementar su seguridad. Las soluciones van desde la mejora de la educación de los usuarios, pasando por la tecnología, hasta la escritura de un mejor software.

Uno de los conceptos más importantes a la que se adhieren la mayoría de los profesionales de la seguridad es la *teoría de la defensa en profundidad*, que

afirma que más capas de defensa son mejores que menos capas. La idea básica aquí es que debemos tener varios niveles de seguridad, de manera que, si se viola uno de ellos, aún quedan otros niveles de defensa. Por supuesto, esta teoría se aplica a cualquier tipo de seguridad. Pensemos en una casa con una reja de hierro cerrada, alta y con picos a su alrededor, detectores de movimiento en el jardín, dos candados especiales en la puerta frontal y un sistema de alarma contra robos computarizado en su interior.

Aunque cada técnica es valiosa por sí sola, para robar la casa el ladrón tendría que vencerlas a todas. Los sistemas computacionales con una seguridad apropiada son como esta casa, con varios niveles de seguridad. En esta sección, veremos los principales métodos, herramientas y técnicas que pueden utilizarse para mejorar la resistencia a las amenazas. Tengamos en cuenta que algunas técnicas de mejora de la seguridad son más propias de la protección que de la seguridad y se tratan en el siguiente módulo.

Política de seguridad.

El primer paso para mejorar la seguridad de cualquier aspecto de la informática es tener una política de seguridad. Las políticas varían mucho, pero generalmente incluyen una declaración de lo que se está asegurando. Por ejemplo, una política puede establecer que todas las aplicaciones accesibles desde el exterior deben someterse a una revisión de código antes de ser desplegadas, o que los usuarios no deben compartir sus contraseñas, o que todos los puntos de conexión entre una empresa y el exterior deben tener escaneos de puertos cada seis meses.

Sin una política establecida, es imposible que los usuarios y los administradores sepan lo que está permitido, lo que es obligatorio y lo que no está permitido. La política es una hoja de ruta hacia la seguridad, y si un sitio está tratando de pasar de menos seguro a más seguro, necesita un mapa para saber cómo llegar allí. Una vez establecida la política de seguridad, las personas a las que afecta deben conocerla bien. Debe ser su guía. La política también debe ser un documento vivo que se revise y actualice periódicamente para garantizar que sigue siendo pertinente y se sigue cumpliendo.

Evaluación de la vulnerabilidad.

¿Cómo podemos determinar si una política de seguridad se ha aplicado correctamente? La mejor manera es ejecutar una evaluación de la vulnerabilidad. Estas evaluaciones pueden abarcar un amplio campo, desde la ingeniería social hasta el escaneo de puertos, pasando por la evaluación de riesgos. La evaluación de riesgos, por ejemplo, intenta valorar los activos de la entidad en cuestión (un programa, un equipo de gestión, un sistema o una instalación) y determinar las probabilidades de que un incidente de seguridad afecte a la entidad y disminuya su valor. Cuando se conocen las probabilidades

de sufrir una pérdida y la cuantía de la pérdida potencial, se puede asignar un valor al intento de asegurar la entidad.

La actividad principal de la mayoría de las evaluaciones de vulnerabilidad es una prueba de penetración, en la que se escanea la entidad en busca de vulnerabilidades conocidas. Dado que aquí nos ocupamos de los sistemas operativos y del software que se ejecuta en ellos, nos concentramos en esos aspectos de la evaluación de vulnerabilidades. Los escaneos de vulnerabilidad normalmente se hacen en momentos en que el uso del computador es relativamente bajo, para minimizar su impacto. Cuando es apropiado, se hacen en sistemas de prueba en lugar de sistemas de producción, porque pueden inducir un comportamiento poco feliz de los sistemas o dispositivos de red objetivo.

Un escaneo dentro de un sistema individual puede comprobar una variedad de aspectos del sistema:

- Contraseñas cortas o fáciles de adivinar.
- Programas privilegiados no autorizados, como los programas setuid.
- Programas no autorizados en los directorios del sistema.
- Procesos de duración inesperadamente larga.
- Protecciones inapropiadas en los directorios de usuario y del sistema.
- Protecciones inapropiadas en los archivos de datos del sistema, como el archivo de contraseñas, los controladores de dispositivos o el propio Kernel del sistema operativo.
- Entradas peligrosas en la ruta de búsqueda de un programa, como el directorio actual y cualquier directorio de fácil escritura como /tmp.
- Cambios en los programas del sistema detectados mediante valores de suma de comprobación.
- Demonios de red inesperados u ocultos.

Cualquier problema detectado por un escáner de seguridad puede arreglarse automáticamente o informarse a los gestores del sistema.

Los computadores conectados en red son mucho más susceptibles de sufrir ataques de seguridad que los sistemas independientes. En lugar de ataques desde un conjunto conocido de puntos de acceso, como los terminales conectados directamente, nos enfrentamos a ataques desde un conjunto desconocido y amplio de puntos de acceso, un problema de seguridad potencialmente grave. En menor medida, los sistemas conectados a líneas telefónicas a través de módems también están más expuestos.

De hecho, muchas organizaciones, públicas o privadas, consideran que un sistema es tan seguro como su conexión más lejana. Por ejemplo, sólo se puede

acceder a un sistema de alto secreto desde un edificio también considerado de alto secreto. El sistema pierde su calificación de alto secreto si puede producirse cualquier forma de comunicación fuera de ese entorno. Algunas instalaciones gubernamentales toman precauciones de seguridad extremas.

Los conectores que conectan un terminal al computador seguro se guardan bajo llave en una caja fuerte en la oficina cuando el terminal no está en uso. Una persona debe tener una identificación adecuada para acceder al edificio y a su oficina, debe conocer una combinación física de la cerradura y debe conocer la información de autenticación del propio computador para poder acceder al mismo, un ejemplo de autenticación multifactorial.

Los escaneos de vulnerabilidad pueden aplicarse a las redes para resolver algunos de los problemas de seguridad de la red. Los escaneos buscan en una red los puertos que responden a una solicitud. Si hay servicios habilitados que no deberían estarlo, se puede bloquear el acceso a ellos o desactivarlos. A continuación, los escáneres determinan los detalles de la aplicación que escucha en ese puerto e intentan determinar si tiene alguna vulnerabilidad conocida. Comprobar esas vulnerabilidades puede determinar si el sistema está mal configurado o carece de los parches necesarios.

Por último, sin embargo, consideremos el uso de escáneres de puertos en manos de un atacante en lugar de alguien que intenta mejorar la seguridad. Estas herramientas podrían ayudar a los atacantes a encontrar vulnerabilidades que atacar. Afortunadamente, es posible detectar los escáneres de puertos a través de la detección de anomalías. Es un reto general para la seguridad que las mismas herramientas puedan ser utilizadas para el bien y para el mal. De hecho, algunas personas abogan por la seguridad a través de la oscuridad, afirmando que no deberían escribirse herramientas para comprobar la seguridad, porque dichas herramientas pueden utilizarse para encontrar, y explotar, agujeros de seguridad.

Otros creen que este enfoque de la seguridad no es válido, señalando, por ejemplo, que los atacantes podrían escribir sus propias herramientas. Parece razonable que la seguridad a través de la oscuridad se considere una de las capas de la seguridad, sólo mientras no sea la única. Por ejemplo, una empresa podría publicar toda la configuración de su red, pero mantener esa información en secreto hace más difícil que los intrusos sepan qué atacar. Sin embargo, incluso en este caso, una empresa que asuma que esa información seguirá siendo un secreto, tiene una falsa sensación de seguridad.

Prevención de intrusiones.

La seguridad de los sistemas e instalaciones está íntimamente ligada a la detección y prevención de intrusiones. La prevención de intrusiones, como su nombre indica, se esfuerza por detectar los intentos de intrusión o el éxito de estas en los sistemas informáticos y por iniciar las respuestas adecuadas a las

intrusiones. La prevención de intrusiones abarca un amplio abanico de técnicas entre las que se encuentran las siguientes:

- El momento en que se produce la detección. La detección puede producirse en tiempo real (mientras se produce la intrusión) o a posteriori.
- Los tipos de entradas examinadas para detectar la actividad intrusiva. Estos pueden incluir comandos de Shell de usuario, llamadas al sistema de procesos y cabeceras o contenidos de paquetes de red. Algunas formas de intrusión pueden ser detectadas sólo mediante la correlación de información de varias fuentes.
- La gama de capacidades de respuesta. Las formas simples de respuesta incluyen alertar a un administrador de la intrusión potencial o detener de alguna manera la actividad potencialmente intrusiva. Por ejemplo, matando un proceso involucrado en dicha actividad. En una forma sofisticada de respuesta, un sistema podría desviar de forma transparente la actividad de un intruso a un a lo que se denomina un tarro de miel (honeypot), un recurso falso que se deja expuesto al atacante. El recurso parece real para el atacante y permite al sistema monitorizar y obtener información sobre el ataque.

Estos grados de libertad en el espacio de diseño para detectar intrusiones han dado lugar a una amplia gama de soluciones, conocidas como sistemas de prevención de intrusiones (IPS: Intrusion Prevention Systems) y sistemas de detección de intrusiones (IDS: Intrusion Detection Systems). Los IPS actúan como cortafuegos que se modifican a sí mismos, dejando pasar el tráfico a menos que se detecte una intrusión (en cuyo caso el tráfico se bloquea). Los sistemas IDS activan una alarma cuando se detecta una intrusión.

Los sistemas IDS pueden clasificarse de la siguiente manera:

- **IDS basados en el host.** Monitorea las características de un solo host y los eventos que ocurren dentro de ese host para detectar actividades sospechosas.
- **IDS basados en la red.** Supervisa el tráfico de la red para determinados segmentos o dispositivos de la red y analiza los protocolos de red, transporte y aplicación para identificar actividades sospechosas.

Un IDS consta de tres componentes lógicos:

- **Sensores.** Los sensores se encargan de recoger datos. La entrada para un sensor puede ser cualquier parte de un sistema que pueda contener evidencia de una intrusión. Los tipos de entrada a un sensor incluyen paquetes de red, archivos de registro y rastros de llamadas al sistema. Los sensores recogen y envían esta información al analizador.

- **Analizadores.** Los analizadores reciben información de uno o más sensores o de otros analizadores. El analizador se encarga de determinar si se ha producido una intrusión. La salida de este componente es una indicación de que se ha producido una intrusión. La salida puede incluir pruebas que apoyen la conclusión de que se ha producido una intrusión. El analizador puede proporcionar una guía sobre las acciones a tomar como resultado de la intrusión.
- **Interfaz de usuario.** La interfaz de usuario de un IDS permite al usuario ver los resultados del sistema o controlar el comportamiento de este. En algunos sistemas, la interfaz de usuario puede equivaler a un componente de gestión, director o consola.

Los sistemas IDS suelen estar diseñados para detectar el comportamiento de los intrusos humanos, así como el comportamiento del software malicioso.

Pero ¿qué es una intrusión? Definir apropiadamente el concepto de intrusión resulta bastante difícil, por lo que los IPS e IDS actuales suelen conformarse con uno de los dos enfoques menos ambiciosos. En el primero, llamado detección basada en firmas (signatures), se examina la entrada del sistema o el tráfico de red en busca de patrones de comportamiento específicos (o firmas) que se sabe que indican ataques. Un ejemplo sencillo de detección basada en firmas es el escaneo de paquetes de red en busca de la cadena “/etc/passwd” dirigida a un sistema UNIX. Otro ejemplo es el software de detección de virus, que escanea binarios o paquetes de red en busca de virus conocidos.

El segundo enfoque, normalmente llamado detección de anomalías, intenta, mediante diversas técnicas, detectar comportamientos anómalos en los sistemas de computación. Por supuesto, no toda la actividad anómala del sistema indica una intrusión, pero la presunción es que las intrusiones suelen inducir un comportamiento anómalo. Existen dos enfoques para la detección estadística de anomalías y son los siguientes:

- **Detección por umbral.** Este enfoque consiste en definir umbrales, independientes del usuario, para la frecuencia de ocurrencia de diversos eventos.
- **Basado en el perfil.** Se desarrolla un perfil de la actividad de cada usuario y se utiliza para detectar cambios en el comportamiento de las cuentas individuales.

Un ejemplo de detección de anomalías es la monitorización de las llamadas al sistema de un proceso demonio para detectar si el comportamiento de las llamadas al sistema se desvía de los patrones normales, indicando posiblemente que ha sido explotado un desbordamiento de búfer en el programa demonio para corromper su comportamiento. Otro ejemplo es la monitorización de los comandos del Shell para detectar comandos anómalos de un determinado

usuario o detectar un inicio de sesión anormal de un usuario, lo que puede indicar que un atacante ha conseguido acceder a la cuenta de ese usuario.

La detección basada en firmas y la detección de anomalías pueden verse como dos caras de la misma moneda. La detección basada en firmas intenta caracterizar los comportamientos peligrosos y detectar cuándo se produce uno de estos comportamientos, mientras que la detección de anomalías intenta caracterizar los comportamientos normales (o no peligrosos) y detectar cuando se produce algo distinto a estos comportamientos.

Sin embargo, estos diferentes enfoques dan lugar a IPS con propiedades muy diferentes. En particular, la detección de anomalías puede encontrar métodos de intrusión previamente desconocidos (los llamados ataques de día cero). La detección basada en firmas, en cambio, sólo identificará los ataques conocidos que puedan codificarse en un patrón reconocible. Por lo tanto, los nuevos ataques que no estaban contemplados cuando se generaron las firmas evadirán la detección basada en firmas. Este problema es bien conocido por los proveedores de software de detección de virus, que deben lanzar nuevas firmas con gran frecuencia a medida que se detectan nuevos virus de forma manual.

Sin embargo, la detección de anomalías no es necesariamente superior a la detección basada en firmas. De hecho, un reto importante para los sistemas que intentan la detección de anomalías es establecer un marco de referencia para describir con precisión lo que constituye el comportamiento normal del sistema. Si el sistema ya ha sido penetrado en el momento de generar el marco de referencia, entonces la actividad intrusiva puede incluirse en ese marco normal. Incluso si el marco de referencia del sistema es generado cuando éste está limpio, sin influencia de comportamiento intrusivo, ese marco de referencia debe dar una imagen bastante completa del comportamiento normal. De lo contrario, el número de falsos positivos (falsas alarmas) o, peor aún, de falsos negativos (intrusiones no detectadas) será excesivo.

Como principio general para los IPS e IDS podemos establecer que: para que sean fáciles de usar, deben ofrecer una tasa de falsas alarmas extremadamente baja. Pero, conseguir un índice de falsas alarmas que sea lo suficientemente bajo es un reto especialmente serio para los sistemas de detección de anomalías, debido a las dificultades para evaluar de la mejor forma posible el comportamiento normal del sistema.

En cuanto a los tipos de atacantes enumerados anteriormente, la detección de anomalías es eficaz contra los hackers, que probablemente no imitan los patrones de comportamiento de las cuentas de las que se apropian. Por otro lado, estas técnicas pueden ser incapaces de hacer frente a los falsificadores. Para este tipo de ataques, los enfoques basados en firmas pueden ser capaces de reconocer eventos y secuencias que, en contexto, revelan la penetración.

En la práctica, un sistema puede emplear una combinación de ambos enfoques para ser eficaz contra una amplia gama de ataques.

Una herramienta fundamental para la detección de intrusos es el *registro de auditoría*. Debe mantenerse algún registro de la actividad continua de los usuarios como entrada a un IDS. Básicamente, se utilizan dos planos:

- **Registros de auditoría nativos.** Prácticamente todos los sistemas operativos multiusuario incluyen un software de contabilidad que recoge información sobre la actividad de los usuarios. La ventaja de utilizar esta información es que no se necesita ningún software de recopilación adicional. La desventaja es que los registros de auditoría nativos pueden no contener la información necesaria o pueden no contenerla en una forma conveniente.
- **Registros de auditoría específicos para la detección.** Se puede implementar una instalación de recopilación que genere registros de auditoría que contengan sólo la información requerida por el IDS. Una de las ventajas de este enfoque es que puede ser independiente del proveedor y ser portado a una variedad de sistemas. La desventaja es la sobrecarga que supone tener, en efecto, dos paquetes de contabilidad funcionando en una máquina.

Un buen ejemplo de registros de auditoría específicos para la detección es el desarrollado por Dorothy Denning. Cada registro de auditoría contiene los siguientes campos:

- **Asunto.** Iniciadores de las acciones. Un sujeto suele ser un usuario de terminal, pero también puede ser un proceso que actúa en nombre de usuarios o grupos de usuarios. Toda la actividad surge a través de comandos emitidos por sujetos. Los sujetos pueden agruparse en diferentes clases de acceso, y estas clases pueden solaparse.
- **Acción.** Operación realizada por el sujeto sobre o con un objeto; por ejemplo, iniciar sesión, leer, realizar E/S y ejecutar.
- **Objeto.** Receptores de acciones. Los ejemplos incluyen archivos, programas, mensajes, registros, terminales, impresoras y estructuras creadas por el usuario o el programa. Cuando un sujeto es el receptor de una acción, como el correo electrónico, entonces ese sujeto se considera un objeto. Los objetos pueden agruparse por tipo. La granularidad de los objetos puede variar según el tipo de objeto y el entorno. Por ejemplo, las acciones de la base de datos pueden ser auditadas para la base de datos en su conjunto o a nivel de registro.
- **Condición de excepción.** Denota qué condición de excepción, si la hay, se plantea al regresar.
- **Uso de recursos.** Lista de elementos cuantitativos en la que cada elemento da la cantidad utilizada de algún recurso (por ejemplo, número de líneas

impresas o mostradas, número de registros leídos o escritos, tiempo de procesador, unidades de E/S utilizadas, tiempo transcurrido de la sesión).

- **Tiempo.** Identificador único de fecha y hora que especifican el momento en que tuvo lugar la acción.

La mayoría de las operaciones de los usuarios se componen de una serie de acciones elementales. Por ejemplo, una copia de archivo implica la ejecución del comando de usuario, que incluye la validación de acceso y la configuración de la copia, más la lectura de un archivo, más la escritura en otro archivo.

La descomposición de una operación de usuario en acciones elementales tiene tres ventajas:

- Dado que los objetos son las entidades protegibles en un sistema, el uso de acciones elementales permite una auditoría de todo el comportamiento que afecta a un objeto. Así, el sistema puede detectar los intentos de subversión de los controles de acceso (observando una anomalía en el número de condiciones de excepción devueltas) y puede detectar las subversiones exitosas (observando una anomalía en el conjunto de objetos accesibles al sujeto).
- Los registros de auditoría de un solo objeto y una sola acción simplifican el modelo y la implementación.
- Debido a la estructura simple y uniforme de los registros de auditoría específicos de la detección, puede ser relativamente fácil obtener esta información o al menos parte de ella mediante un mapeo directo de los registros de auditoría nativos existentes a los registros de auditoría específicos de la detección.

Finalmente, cabría comentar que, la investigación continúa mejorando las técnicas de detección de anomalías. El software de detección de intrusos está evolucionando para implementar firmas, algoritmos de anomalías y otros algoritmos y para combinar los resultados para llegar a una tasa de detección de anomalías más exacta.

Protección antivirus

Como hemos visto, los virus pueden causar, y de hecho causan, estragos en los sistemas. Por tanto, la protección contra los virus es una importante preocupación en materia de seguridad. A menudo se utilizan programas antivirus para proporcionar esta protección. Algunos de estos programas sólo son eficaces contra determinados virus conocidos. Funcionan buscando en todos los programas de un sistema el patrón específico de instrucciones que se sabe que componen el virus. Cuando encuentran un patrón conocido, eliminan las instrucciones, desinfectando el programa. Los programas antivirus pueden tener catálogos de miles de virus que buscan.

Tanto los virus como los programas antivirus son cada vez más sofisticados. Algunos virus se modifican a sí mismos a medida que infectan otro software para evitar el enfoque básico de coincidencia de patrones de los programas antivirus. A su vez, los programas antivirus buscan ahora familias de patrones en lugar de un único patrón para identificar un virus. De hecho, algunos programas antivirus aplican diversos algoritmos de detección. Pueden descomprimir virus comprimidos antes de buscar una firma. Algunos también buscan anomalías en los procesos. Un proceso que abre un archivo ejecutable para escribir es sospechoso, por ejemplo, a menos que sea un compilador. Otra técnica popular es ejecutar un programa en una caja de arena (Sandbox), que es una sección controlada o emulada del sistema. El software antivirus analiza el comportamiento del código en la caja de arena antes de dejar que se ejecute sin supervisión. Algunos programas antivirus también ponen un escudo completo en lugar de limitarse a analizar los archivos dentro de un sistema de archivos. Buscan en los sectores de arranque, en la memoria, en el correo electrónico entrante y saliente, en los archivos que se descargan, en los archivos de los dispositivos o soportes extraíbles, etc.

La mejor protección contra los virus informáticos es la prevención, o la práctica de la informática segura. Adquirir software sin abrir de los proveedores y evitar las copias gratuitas o piratas de fuentes públicas o de intercambio de discos es la vía más segura para evitar la infección. Sin embargo, incluso las nuevas copias de aplicaciones de software legítimas no son inmunes a la infección por virus: en unos pocos casos, empleados descontentos de una empresa de software han infectado las copias maestras de programas de software para causar un daño económico a la empresa. Del mismo modo, los dispositivos de hardware pueden venir de fábrica preinfectados para su comodidad. En el caso de los macrovirus, una defensa consiste en intercambiar documentos de Microsoft Word en un formato de archivo alternativo llamado formato de texto enriquecido (RTF). A diferencia del formato nativo de Word, el RTF no incluye la capacidad de adjuntar macros.

Otra defensa es evitar abrir cualquier archivo adjunto de correo electrónico de usuarios desconocidos. Por desgracia, la historia ha demostrado que las vulnerabilidades del correo electrónico aparecen tan rápido como se solucionan. Por ejemplo, en el año 2000, el virus Love Bug se extendió mucho al viajar en mensajes de correo electrónico que simulaban ser notas de amor enviadas por amigos de los receptores. Una vez que el receptor abría el script de Visual Basic adjunto, el virus se propagaba enviándose a las primeras direcciones de la lista de contactos de correo electrónico del receptor. Afortunadamente, salvo por la obstrucción de los sistemas de correo electrónico y las bandejas de entrada de los usuarios, era relativamente inofensivo. Sin embargo, anuló la estrategia defensiva de abrir archivos adjuntos sólo de personas conocidas por el receptor. Un método de defensa más eficaz es evitar abrir cualquier archivo adjunto de correo electrónico que

contenga código ejecutable. Algunas empresas aplican ahora esta política eliminando todos los archivos adjuntos que llegan con los mensajes de correo electrónico.

Otra salvaguarda, aunque no previene la infección, permite una detección temprana. El usuario debe empezar por reformatar completamente el disco duro, especialmente el sector de arranque, que suele ser el objetivo de los ataques virales. Sólo se carga software seguro, y se toma una firma de cada programa mediante un cálculo seguro de compilación de mensajes. El nombre del archivo resultante y la lista de compendio de mensajes asociada deben mantenerse libres de accesos no autorizados. Periódicamente, o cada vez que se ejecuta un programa, el sistema operativo vuelve a calcular la firma y la compara con la firma de la lista original; cualquier diferencia sirve como advertencia de una posible infección. Esta técnica puede combinarse con otras. Por ejemplo, se puede utilizar un escáner antivirus de alto nivel, como una caja de arena (Sandbox), y si un programa pasa la prueba, se puede crear una firma para él. Si las firmas coinciden la próxima vez que se ejecute el programa, no será necesario volver a escanearlo.

Auditoría, contabilidad y registro

La auditoría, la contabilidad y el registro pueden disminuir el rendimiento del sistema, pero son útiles en varias áreas, incluida la seguridad. El registro puede ser general o específico. Todas las ejecuciones de llamadas del sistema pueden ser registradas para analizar el comportamiento del programa (o su mal comportamiento). Más típicamente, se registran los eventos sospechosos. Los fallos de autenticación y de autorización pueden decirnos mucho sobre los intentos de intrusión.

La contabilidad es otra herramienta potencial en el kit de un administrador de seguridad. Se puede utilizar para encontrar cambios en el rendimiento, que a su vez pueden revelar problemas de seguridad. Uno de los primeros intentos de intrusión en un computador UNIX fue detectado por Cliff Stoll cuando estaba examinando los registros de contabilidad y detectó una anomalía.

Cortafuegos (Firewalls) para proteger sistemas y redes

Si nos preguntamos cómo se puede conectar de forma segura un computador de confianza a una red que no es de confianza, encontraremos que una solución es el uso de un cortafuegos para separar los sistemas de confianza de los que no lo son. Un cortafuegos es un computador, dispositivo, proceso o router que se sitúa entre el sistema de confianza y el que no lo es. Un cortafuegos de red limita el acceso a la red entre los múltiples dominios de seguridad y supervisa y registra todas las conexiones. También puede limitar las conexiones en función de la dirección de origen o de destino, el puerto de origen o de destino, o la dirección de la conexión. Por ejemplo, los servidores web utilizan HTTP

para comunicarse con los navegadores web. Por lo tanto, un cortafuegos puede permitir sólo el paso de HTTP desde todos los hosts fuera del cortafuegos al servidor web dentro del cortafuegos. El primer gusano, el gusano de Internet Morris, utilizaba el protocolo Finger para entrar en los ordenadores, por lo que no se permitiría el paso de Finger, por ejemplo.

De hecho, un cortafuegos de red puede separar una red en múltiples dominios. Una implementación común tiene a Internet como el dominio no confiable; una red semiconfiable y semisegura, llamada la zona desmilitarizada (DMZ), como otro dominio; y los computadores de una compañía como un tercer dominio. Se permiten las conexiones desde Internet a los computadores de la DMZ y desde los computadores de la empresa a Internet, pero no se permiten desde Internet o los computadores de la DMZ a los computadores de la empresa. Opcionalmente, se pueden permitir comunicaciones controladas entre la DMZ y un computador de la empresa o más. Por ejemplo, un servidor web en la DMZ puede necesitar consultar un servidor de base de datos en la red corporativa. Sin embargo, con un cortafuegos, el acceso está contenido, y cualquier sistema DMZ que sea violado sigue sin poder acceder a los computadores de la empresa.

Por supuesto, el propio cortafuegos debe ser seguro y a prueba de ataques. De lo contrario, su capacidad para asegurar las conexiones puede verse comprometida. Además, los cortafuegos no impiden los ataques que hacen de túnel, o que viajan dentro de los protocolos o conexiones que el cortafuegos permite. Un ataque de desbordamiento de búfer a un servidor web no será detenido por el cortafuegos, por ejemplo, porque la conexión HTTP está permitida; es el contenido de la conexión HTTP el que alberga el ataque. Del mismo modo, los ataques de denegación de servicio pueden afectar a los cortafuegos tanto como a cualquier otra máquina. Otra vulnerabilidad de los cortafuegos es el spoofing, en el que un host no autorizado se hace pasar por un host autorizado al cumplir algún criterio de autorización. Por ejemplo, si una regla del cortafuegos permite una conexión desde un host e identifica ese host por su dirección IP, entonces otro host podría enviar paquetes usando esa misma dirección y ser permitido a través del cortafuegos.

Además de los cortafuegos de red más comunes, hay otros tipos de cortafuegos más nuevos, cada uno con sus ventajas y desventajas. Un cortafuegos personal es una capa de software incluida en el sistema operativo o añadida como aplicación. En lugar de limitar la comunicación entre dominios de seguridad, limita la comunicación hacia (y posiblemente desde) un determinado host. Un usuario podría añadir un cortafuegos personal a su PC para que un troyano no pueda acceder a la red a la que está conectado el PC, por ejemplo. Un cortafuegos proxy de aplicaciones entiende los protocolos que las aplicaciones hablan a través de la red. Por ejemplo, el SMTP se utiliza para la transferencia de correo. Un proxy de aplicación acepta una conexión como lo haría un servidor SMTP y luego inicia una conexión con el servidor SMTP de destino.

original. Puede supervisar el tráfico a medida que reenvía el mensaje, vigilando y deshabilitando los comandos ilegales, los intentos de explotar errores, etc. Algunos cortafuegos están diseñados para un protocolo específico. Un cortafuegos XML, por ejemplo, tiene el propósito específico de analizar el tráfico XML y bloquear el XML no permitido o malformado. Los cortafuegos de llamadas del sistema se sitúan entre las aplicaciones y el núcleo, supervisando la ejecución de las llamadas del sistema. Por ejemplo, en Solaris 10, la función de "mínimo privilegio" implementa una lista de más de cincuenta llamadas al sistema que los procesos pueden o no pueden realizar. Por ejemplo, a un proceso que no necesita generar otros procesos se le puede quitar esa capacidad.

Gestión de parches

La gestión de parches es la forma en que las empresas adquieren, prueban e instalan múltiples parches (conjunto de códigos) en diferentes sistemas operativos, aplicaciones dentro de la red para protegerlos de posibles amenazas y garantizar la continuidad del negocio. Los parches se añaden al código actual para mantener temporalmente la seguridad del software hasta que los proveedores publiquen la versión actualizada. Es responsabilidad del administrador de TI construir una infraestructura de TI altamente configurada y protegerla de las vulnerabilidades. La gestión de parches consiste en el control administrativo de las actualizaciones de los sistemas operativos (SO), las plataformas o las aplicaciones. Implica identificar las características del sistema que se pueden mejorar o corregir, diseñar esa mejora o corrección, lanzar el paquete de actualización y validar la instalación de dichas actualizaciones. La ejecución de parches, junto con las actualizaciones de software y la reconfiguración del sistema, es una parte importante de la gestión del ciclo de vida de los sistemas de TI.

Aunque terminologías como *actualización de software* y *parche* pueden parecer sinónimas, la diferencia entre ambas es que la primera proporciona a los titulares de las licencias de software nuevas funciones. La segunda despliega códigos para mitigar las brechas de seguridad de la infraestructura de TI de una organización. La gestión de parches forma parte de los esfuerzos de los equipos internos de TI para mantener la eficacia de la empresa y garantizar un entorno de TI seguro.

La gestión de parches y de versiones son actividades esenciales en los entornos de TI que abarcan todo el panorama de la infraestructura (firmware) y las soluciones de software. Dentro de las mejores prácticas de la Biblioteca de Infraestructura de Tecnologías de Información (ITIL), la gestión de parches cae bajo la etiqueta de gestión de versiones y es necesaria por varias razones importantes, que incluyen:

- **Resolución de errores.** el código mal elaborado a veces puede afectar la estabilidad o el rendimiento de un producto.
- **Gestión de vulnerabilidades de seguridad.** el código con errores a veces deja un sistema vulnerable a ser explotado con el propósito de dañar el sistema o los datos que mantiene, obtener acceso administrativo remoto o filtrar datos.
- **Mejora de funciones.** a medida que los proveedores mejoran sus productos con el tiempo, los clientes que ya han comprado generalmente tienen acceso a mejoras con actualizaciones de firmware o software.
- **Mantenimiento del soporte del proveedor.** los proveedores a menudo solo admiten algunas de las versiones o niveles de lanzamiento más recientes. Esto se debe a que generalmente solo administran entornos de prueba de una pequeña cantidad de versiones y no pueden publicar actualizaciones de manera rentable para el código anterior.

Los parches son líneas de código nuevas o actualizadas que determinan el comportamiento de un sistema operativo, una plataforma o una aplicación. Por lo general, se lanzan según sea necesario para corregir errores en el código, mejorar el rendimiento de las características actuales o agregar nuevas funciones al software. Los parches se lanzan como actualizaciones del software actual y no son sistemas operativos, plataformas ni aplicaciones compilados recientemente. Pueden afectar al hardware. Por ejemplo, en una ocasión se lanzaron parches que alteraron la gestión de la memoria, crearon límites de carga (Load Fences) y entrenaron al hardware predictor de saltos en respuesta a los ataques Meltdown y Spectre de 2018 que tenían como objetivo los microchips.

Debido a que estas modificaciones se suelen distribuir más rápido que las versiones de software principales o secundarias, los parches se utilizan como herramientas de seguridad de la red contra ataques cibernéticos, fallos de seguridad y malware (puntos vulnerables causados por amenazas nuevas, parches desactualizados o errores de configuración del sistema).

La importancia de gestionar los parches radica en que su ejecución puede ser complicada sin se carece de una planificación. Los entornos de TI empresariales pueden contener cientos de sistemas que operan equipos muy grandes. Esto requiere miles de parches de seguridad, correcciones de errores y cambios en la configuración. Examinar manualmente los archivos de datos para identificar sistemas, actualizaciones y parches puede ser una tarea abrumadora, incluso con una herramienta de análisis. Las herramientas de gestión de parches ayudan a generar informes claros sobre cuáles sistemas tienen parches, cuáles los necesitan y cuáles no cumplen con las normas.

Teniendo en mente que durante el primer trimestre de 2020 se produjeron más de 445 millones de ciberataques, y que cada ciberataque pone de manifiesto la

necesidad de contar con una solución de gestión de parches, concluimos que la gravedad de un sistema sin parches va desde la pérdida de productividad, el retraso de los proyectos empresariales, la violación de los datos de los empleados y los clientes hasta el daño de toda la red de sistemas, que costará a la empresa millones de dólares.

En la actualidad, las 4 principales razones que se esgrimen para justificar el añadido de parches a los sistemas son:

- **Reduce la exposición a los ciberataques.** La aplicación de parches protege los datos de una empresa de los ataques de malware y ransomware al corregir las vulnerabilidades y los errores de seguridad. Los parches evitan que los hackers exploten los detalles de la empresa y la información valiosa.
- **Disminuye el tiempo de inactividad del sistema.** Los parches garantizan que la tecnología de la empresa rinda al máximo y mejoran los niveles de productividad de los empleados. Las empresas pueden llevar a cabo proyectos empresariales sin esfuerzo y con un menor tiempo de inactividad del sistema.
- **Garantiza el buen funcionamiento de la empresa.** Al dirigir las operaciones empresariales en el mundo VUCA³, los ejecutivos han cambiado las prioridades de TI para garantizar una mayor seguridad con sus sistemas de acceso remoto. La gestión de parches ayuda al equipo de TI de una organización a trabajar en la adversidad con mayor agilidad.
- **Asegura los datos de empleados y clientes.** Los datos de las empresas son más importantes que nunca. Un software seguro evita que una empresa pierda los datos de sus clientes y empleados y se enfrente a consecuencias financieras y legales.

La gestión de parches no es una tarea sencilla para ninguna empresa. Ahora, con la creciente complejidad de la infraestructura de TI y la integración de múltiples aplicaciones en los sistemas existentes, la gestión de parches se ha convertido en una tarea que requiere muchos recursos para las organizaciones. El proceso de gestión de parches varía según el tamaño y la estructura de la organización; sin embargo, el proceso básico de gestión de parches es el mismo. El equipo de TI despliega un parche cuando detecta una vulnerabilidad en el sistema operativo o el software existente. Esto protege temporalmente la red de posibles amenazas hasta que los desarrolladores del software específico publiquen la versión actualizada. Veamos el proceso de gestión de parches en cuatro fases:

³ VUCA es una sigla que significa volatilidad, incertidumbre, complejidad y ambigüedad, una combinación de cualidades que, en conjunto, caracterizan la naturaleza de algunas condiciones y situaciones difíciles. El término también se dice a veces para representar los adjetivos: volátil, incierto, complejo y ambiguo.

- **Etapla 1 - Hacer un balance del hardware y el software de la empresa.** El primer paso es asegurarse de que los recursos necesarios están en su lugar y distribuidos a los empleados que manejan el proceso de extremo a extremo.

En segundo lugar, hacer un balance de los activos de software y hardware de la organización. Necesitamos saber lo que se tiene para entender lo que se necesita parchear. Este es un paso crítico en cualquier proceso de gestión de parches. Debemos crear un documento con los detalles de todos los servidores, software, aplicaciones, bases de datos, hardware y otros equipos conectados a la red de la organización. Al hacerlo, añadimos al documento detalles de los sistemas y software de terceros que el equipo ignoró en el pasado. También podrían ser una amenaza potencial para el entorno actual. Debemos hacer un balance del inventario actual lo que ayudará a localizar al dispositivo y a su propietario, a identificar el software o el sistema operativo vulnerable y a decidir el número de parches necesarios para su implantación.

- **Etapla 2 - Escanear y supervisar la red existente.** El escaneo nos ayuda a identificar las vulnerabilidades en la red de TI existente mediante la detección de líneas débiles en el hardware y el software de la organización. De este modo, podremos clasificar las vulnerabilidades, evaluar la gravedad y decidir el número de parches necesarios para su implantación. Aunque es esencial documentar los activos de la organización antes de comenzar el proceso de aplicación de parches, es igualmente importante anotar los sistemas que se incluyen y excluyen de la actividad de exploración. Una vez que hecha una lista de dispositivos vulnerables, debemos priorizar y actuar sobre los más críticos. Como todo el hardware y el software están interconectados en la red, es aconsejable escanear y supervisar todo el sistema para ver el éxito de este proceso.
- **Etapla 3 - Probar los parches.** Un paso esencial es probar los parches antes de desplegarlos. El nivel de las pruebas depende del nivel de vulnerabilidad de un software o un dispositivo. Es aconsejable ejecutar el parche de prueba durante las horas no laborables. Probar los parches evita que las organizaciones sufran consecuencias en el futuro y garantiza la continuidad de las operaciones comerciales. Los pasos que se siguen para probar los parches son:
 - Ejecución de casos de prueba.
 - Desplegar los parches en las aplicaciones de destino.
 - Comprobar el rendimiento de todas las funcionalidades asociadas a la aplicación.
 - Supervisión del rendimiento del sistema de destino antes y después del despliegue del parche.

Hay tres cosas que hay que debemos seguir durante la fase de pruebas:

- En primer lugar, hay que tener un plan de contingencia. Esto para hacer una copia de seguridad de los datos y revertir el proceso de parcheo si las pruebas dan resultados negativos.
 - En segundo lugar, aunque podemos omitir las directrices ITIL (procedimientos de gestión del cambio) para los parches menores, debemos cumplir los principios de gestión del cambio para todos los procesos de parcheo importantes.
 - En tercer lugar, debemos notificar a los empleados los próximos calendarios de aplicación de parches, el tiempo de inactividad previsto del sistema y su finalidad.
- **Etapas 4 - Despliegue, supervisión y mantenimiento de los parches.** Una vez que se añaden parches al sistema existente, hay que verificar si se cumplen los requisitos de seguridad. La supervisión periódica del sistema tras la aplicación de los parches es un paso importante en el proceso de aplicación de parches. Debemos realizar informes periódicos para supervisar el éxito de la aplicación de los parches y la salud de la red de la empresa.

Además, resulta conveniente tener presente los distintos tipos de gestión de parches. Estas gestiones se pueden clasificar en: manuales y automatizados

- **Gestión manual de parches.** En este proceso, los administradores de TI despliegan manualmente parches y actualizaciones en cada estación de trabajo y software. La ventaja más significativa del despliegue manual es que se pueden lanzar parches durante el horario laboral y no laboral. Puede ocuparse de los servidores, el software o los dispositivos de forma independiente y tener un control total del entorno de aplicación de parches. Por otro lado, el despliegue manual es un proceso que requiere mucho tiempo y deja al equipo de TI con poco tiempo para centrarse en otros proyectos críticos. Además, el despliegue manual requiere muchos recursos y aumenta el coste operativo de la organización.
- **Gestión automatizada de parches.** Las actualizaciones del sistema operativo y de las aplicaciones se entregan automáticamente a través de un servidor de gestión de parches centralizado. Entre los beneficios de una gestión podemos mencionar:
 - Reducción de las infracciones mediante la publicación de parches de seguridad en el momento oportuno.
 - Mejora de la productividad de los empleados al reducir el tiempo de inactividad.
 - Disminuir la carga de trabajo del equipo de TI y permitiéndole centrarse en las tareas críticas.

- Gestionar automáticamente el proceso de aplicación de parches, desde la gestión de activos y la documentación hasta el análisis del rendimiento a medida que la organización crece.

Las soluciones de gestión se pueden combinar con los sistemas de software de automatización para mejorar la configuración y la precisión de los parches y, a su vez, reducir los errores. La automatización incorpora funciones adicionales que permiten identificar sistemas, probarlos y aplicar parches en ellos con menos trabajo manual. Por ejemplo, unos cuantos módulos de Red Hat Ansible Automation Platform pueden automatizar parte de los procesos de ejecución de parches, lo que incluye invocar métodos de ejecución de parches HTTP, ejecutar parches con la herramienta GNU y aplicar (o revertir) todos los parches del sistema disponibles.

Ahora bien, como parte de la gestión de parches siempre puede surgir la pregunta: ¿qué resulta más conveniente implementar un parche o conservar una versión anterior? La mejor práctica es revisar la postura con regularidad y mantenerse al tanto de las actualizaciones para minimizar el riesgo. La infraestructura y el software implementados deben mantenerse dentro del soporte del proveedor para garantizar que las correcciones de seguridad estén disponibles cuando se identifiquen y no se quede afuera. La decisión de implementar un parche, conservar una versión anterior o no hacer nada debe considerar dos enfoques clave:

- **Evaluación del riesgo.** Esto incluye:
 - ¿Cuál es la gravedad de la vulnerabilidad / error?
 - ¿Hay exploits⁴ públicos disponibles para la vulnerabilidad?
 - ¿Tengo sistemas que están expuestos a redes que no son de confianza y que son vulnerables?
 - ¿Qué problemas conocidos se resuelven o se sabe que existen en los parches disponibles?
- **Interoperabilidad.** Es inevitable que haya componentes, ya sean de hardware o software, que, para funcionar correctamente de forma integrada, requieren niveles de parche compatibles en otros componentes integrados. Para evitar romper inadvertidamente la interoperabilidad y crear interrupciones en el entorno, es importante considerar toda la cadena integrada. Esta es la razón clave para completar esta revisión antes de tomar decisiones sobre la aplicación de parches.

Ambos enfoques son comunes, donde se priorizan las versiones anteriores a las actuales. Estos enfoques limitan el riesgo de encontrar problemas / errores no

⁴ Un exploit es un programa informático, una parte de un software o una secuencia de comandos que se aprovecha de un error o vulnerabilidad para provocar un comportamiento no intencionado o imprevisto en un software, hardware o en cualquier dispositivo electrónico.

identificados en nuevos parches, ya que el parche anterior probablemente haya tenido más pruebas de campo. Sin embargo, adoptar este enfoque no significa que el parche siempre se implemente, por ejemplo:

- Se deben considerar las correcciones en el parche más reciente, ya que pueden resolver problemas críticos o riesgos en el parche anterior que no se pueden ignorar.
- A menudo, no hay otra opción que implementar un parche más antiguo o nuevo para satisfacer los requisitos de interoperabilidad.

Otro punto clave que se suele generar es la determinación de cuál es el programa de parches recomendado. Ante ello conviene tener presente las siguientes clases de dispositivos que son enumerados a continuación siguiendo un orden decreciente según el área de superficie de ataque potencial y están alineados con la frecuencia mínima sugerida de revisión y parcheo:

- Sistema operativo de escritorio, protección contra malware y virus, clientes de VPN y herramientas de seguridad, aplicaciones de cliente: Los dispositivos de cliente mensuales a menudo se seleccionan primero como un punto de entrada a una red más confiable. Poner en peligro un punto final puede ser tan simple como engañar a un usuario final para que ejecute un código malicioso con un correo electrónico cuidadosamente formado o phishing para obtener credenciales por teléfono. Una vez que un punto final se ve comprometido, puede ser mucho más fácil obtener acceso a servidores y sistemas críticos a través del movimiento lateral dentro de la red de una organización. Los dispositivos cliente son el área más expuesta de la red, particularmente en entornos donde los usuarios llevan dispositivos entre la red interna y redes que no son de confianza, por ejemplo, redes Wifi-públicas o domésticas.
- Sistema operativo y aplicaciones del servidor: mensualmente
- Dado que el sistema operativo y las aplicaciones que se ejecutan en un servidor son puntos clave de ataque, especialmente aquellos expuestos a redes que no son de confianza, como servidores en la DMZ, estos deben considerarse con mucha más frecuencia. Se recomiendan ciclos de parcheo mensuales para servidores y en entornos extremadamente sensibles se debe considerar un parcheo más regular. Para reducir los gastos generales de la gestión de este proceso, la actualización automatizada debe considerarse internamente o mediante un proveedor de servicios gestionados de confianza.
- Dispositivos físicos y virtuales, hipervisores y herramientas de administración: trimestralmente.
- Con la mayor complejidad, más puntos de integración y una superficie de ataque más amplia, se recomienda revisar estos elementos con más

regularidad que el firmware. Se recomienda priorizar los dispositivos expuestos a entornos que no son de confianza, como Internet.

- Firmware de infraestructura, controladores y software de gestión: semestralmente.

También es necesario actualizar el firmware para mantener los niveles de soporte de los proveedores. Algunos proveedores no conservan versiones de firmware más antiguas en sus laboratorios para brindar soporte rápido. Esto significa que cuando tengamos un problema con una revisión anterior, la primera solicitud de soporte del proveedor será que actualice a una revisión actual, lo que potencialmente ralentizará los tiempos de resolución y creará interrupciones adicionales no planificadas.

A la hora de evaluar la gestión de parches, los aportes clave que permiten realizar una eficiente y dinámica evaluación de esta incluyen:

- Datos de configuración y activos confiables, mantenidos en una base de datos de administración de configuración (CMDB).
- Identificación de sistemas por riesgo y criticidad: cargas de trabajo críticas para el negocio, sistemas que están expuestos a Internet o redes que no son de confianza (es decir, servidores DMZ), sistemas a los que acceden usuarios que no son administradores de confianza.
- Asignaciones de dependencia del sistema: los sistemas que son dependientes deben considerarse en paralelo, ya que los cambios en un sistema pueden afectar a otro.
- Gestión de registros centralizada: recopila datos de registro de los diversos sistemas e infraestructura para garantizar que se conserven durante períodos mínimos y para facilitar la referencia cruzada de los datos de registro entre varios sistemas.
- Datos de monitoreo de estado, capacidad y rendimiento: ayudan con la revisión y el análisis de los impactos esperados o inesperados de la implementación de parches en el medio ambiente.

Estos aportes requieren un conjunto de herramientas de referencia para la gestión de parches y la resolución de vulnerabilidades. Sin estos, el medio ambiente debe catalogarse manualmente y los impactos de una vulnerabilidad deben investigarse lenta y reactivamente. Podemos implementar herramientas adicionales de configuración y administración de parches para automatizar las tareas operativas en el centro de datos, los sistemas y los dispositivos periféricos, incluida la implementación de parches. Lo más importante es que las políticas y los procedimientos de mantenimiento operativo de TI son documentos dinámicos que deben mantenerse, ser sólidos e inequívocos.

Después de la evaluación, podemos desarrollar y ejecutar un plan de proyecto de implementación. El plan de implementación identifica todas las tareas, el orden de las operaciones, las pruebas de referencia y posteriores a la actualización o la evaluación comparativa, las herramientas necesarias, los puntos de reversión y decisión, las interrupciones y las evaluaciones de impacto comercial, la gestión de cambios, los roles y responsabilidades, la gestión de riesgos, los planes de comunicaciones, informes de progreso, alcance y gestión de costos.

Finalmente, podemos establecer que entre las prácticas recomendadas para la gestión de parches se sugieren las siguientes acciones:

- Identificar los sistemas que no cumplen con las normas, que presentan aspectos vulnerables o que no están actualizados.
- Priorizar los parches en función de su posible impacto.
- Ejecutar los parches con regularidad. Por lo general, se distribuyen una vez al mes, o con mayor frecuencia.
- Probar los parches antes de implementarlos en la producción.

Otras soluciones

En la actual batalla entre los diseñadores de CPU, los implementadores de sistemas operativos y los hackers, una técnica particular ha sido útil para defenderse de la inyección de código. Para montar un ataque de inyección de código, los hackers deben ser capaces de deducir la dirección exacta en memoria de su objetivo. Normalmente, esto no es difícil, ya que la disposición de la memoria tiende a ser predecible. Una técnica del sistema operativo llamada Address Space Layout Randomization (ASLR) intenta resolver este problema mediante la aleatorización de los espacios de direcciones, es decir, colocando los espacios de direcciones, como las ubicaciones iniciales de la pila y el cúmulo, en lugares impredecibles. La aleatorización de direcciones, aunque no es infalible, hace que la explotación sea considerablemente más difícil. ASLR es una característica estándar en muchos sistemas operativos, incluyendo Windows, Linux y Mac OS.

En los sistemas operativos móviles como iOS y Android, un enfoque que se suele adoptar es colocar los datos del usuario y los archivos del sistema en dos particiones separadas. La partición del sistema se monta en modo de sólo lectura, mientras que la partición de datos es de lectura y escritura. Este enfoque tiene numerosas ventajas, entre ellas una mayor seguridad: los archivos de la partición del sistema no pueden ser fácilmente manipulados, lo que refuerza la integridad del sistema. Android va un paso más allá al utilizar el mecanismo dm-verity de Linux para realizar un hash criptográfico de la partición del sistema y detectar cualquier modificación.

Bibliografía

Silberschatz, A., Galvin, P. B., & Gagne, G. (2018). *Operating System Concepts, Tenth Edition*. Hoboken, New Jersey: John Wiley & Sons, Inc.

Stallings, W. (2018). *Operating Systems: Internals and Design Principles*, 9th Edition; Editorial: Pearson; ISBN-10: 0134670957; ISBN-13: 978-0134670959

Stallings, W. (2012). *Operating Systems, Internals and Design Principles, Seventh Edition*. Upper Saddle River; New Jersey: Pearson Education, Inc.

Tanenbaum, A. S., & Bos, H. (2015). *Modern Operating Systems, Fourth Edition*. Upper Saddle River, New Jersey: Pearson Education, Inc.

ⁱ Viene de las siglas en inglés D.A.E.MON (Disk And Execution Monitor) y se refiere a un tipo especial de proceso informático no interactivo, es decir, que se ejecuta en segundo plano en vez de ser controlado directamente por el usuario. Este tipo de programas continua en el sistema, es decir, que puede ser ejecutado en forma persistente o reiniciado si se intenta matar el proceso dependiendo de configuración del demonio y políticas del sistema.